SENA

INSTITUCIÓN EDUCATIVA TÉCNICO SUPERIOR

Neiva – Huila, Colombia



TÉCNICO EN PROGRAMACIÓN DE SOFTWARE

MANUAL TÉCNICO

Aplicativo Web "Pizzería Julián"

Arquitectura · Diagramas UML · Base de datos · Codificación · Normas aplicables

Ingeniero desarrollador: ALBER DELFIN PEÑA ORTIGOZA

SENA – INSTITUCIÓN EDUCATIVA TÉCNICO SUPERIOR

Versión 1.0 · Octubre de 2026

Información del documento

Campo	Detalle
Documento	Manual Técnico – Aplicativo Web "Pizzería Julián"
Ingeniero desarrollador	ALBER DELFIN PEÑA ORTIGOZA
Programa de formación	TÉCNICO EN PROGRAMACIÓN DE SOFTWARE – Instructor ALBER DELFIN PEÑA ORTIGOZA
Entidades	SENA – Servicio Nacional de Aprendizaje INSTITUCIÓN EDUCATIVA TÉCNICO SUPERIOR (Neiva, Huila)
Sistema documentado	Sitio web informativo con administración de contenidos de la pizzería "Pizzería Julián" (carpeta `pizza-julian`).
Ubicación del código	`D:\MATERIAL\xampp\htdocs\pizza-julian`
Base de datos	`tecnico-2026-pagina` (MariaDB 10.4.32)
Destinatarios	Desarrolladores, aprendices, instructores, personal de soporte y administradores de infraestructura.
Documento relacionado	Manual de Usuario – Aplicativo Web "Pizzería Julián" (v1.0, octubre de 2026).
Versión / fecha	1.0 – 18 de octubre de 2026

Control de cambios

Versión	Fecha	Descripción	Autor
1.0	18/10/2026	Elaboración del manual técnico: normas, requisitos, arquitectura, diagramas UML, base de datos, codificación, seguridad, pruebas, instalación y mantenimiento.	Ing. ALBER DELFIN PEÑA ORTIGOZA

NOTA
Este manual se elaboró a partir del análisis del código fuente real del proyecto y de pruebas ejecutadas sobre una copia del aplicativo en un entorno equivalente (PHP 8.3 + MariaDB 10.11). Los resultados de las pruebas se presentan en el capítulo 11.

Contenido

Información del documento 2

Contenido 3

1. Introducción 6

1.1 Propósito 6

1.2 Alcance del sistema 6

1.3 Definiciones y siglas 6

1.4 Referencias 7

2. Marco normativo y estándares aplicables 7

2.1 Normas de ingeniería y calidad de software 7

2.2 Seguridad de la información 8

2.3 Accesibilidad y estándares web 8

2.4 Estándares de codificación 8

2.5 Legislación colombiana aplicable 9

2.6 Evaluación de calidad según ISO/IEC 25010:2023 9

3. Descripción general del sistema 10

3.1 Contexto 10

3.2 Tecnologías y versiones 10

3.3 Perfiles de usuario 11

3.4 Restricciones y supuestos 11

4. Especificación de requisitos 11

4.1 Requisitos funcionales 11

4.2 Requisitos no funcionales 12

5. Arquitectura del software 13

5.1 Estilo arquitectónico 13

5.2 Estructura de carpetas 13

5.3 Vista de componentes 15

5.4 Vista de despliegue 16

5.5 Patrones y decisiones de diseño 16

6. Modelado UML 17

6.1 Diagrama de casos de uso general 17

6.2 Diagrama de casos de uso del administrador 18

6.3 Especificación de casos de uso . . . 19
6.4 Diagrama de clases (estructura del código) . . . 20
6.5 Diagramas de secuencia . . . 22
6.6 Diagramas de actividad . . . 24
6.7 Diagrama de estados de la sesión . . . 26
6.8 Diagrama de navegación . . . 27
7. Desarrollo de la base de datos . . . 27
7.1 Características generales . . . 27
7.2 Modelo entidad-relación . . . 28
7.3 Diccionario de datos . . . 28
7.4 Script DDL de creación . . . 30
7.5 Consultas SQL utilizadas por el aplicativo . . . 31
7.6 Análisis de normalización . . . 31
7.7 Recomendaciones para la base de datos . . . 31
7.8 Copias de seguridad . . . 32
8. Explicación de la codificación . . . 32
8.1 Ciclo de una petición . . . 32
8.2 sesion.php – sesión segura y protección CSRF . . . 33
8.3 login.php – autenticación . . . 33
8.4 logout.php – cierre de sesión . . . 34
8.5 imagenes-editor.php – carga segura de imágenes . . . 35
8.6 Editores de contenido (patrón CRUD + PRG) . . . 35
8.7 tema.php y tema.js – banner y paleta dinámica . . . 36
8.8 formulario-contacto.php – registro y correo . . . 36
8.9 Páginas públicas . . . 37
8.10 Interfaz (HTML, CSS y JavaScript) . . . 37
9. Seguridad del aplicativo . . . 37
9.1 Controles implementados frente a OWASP Top 10:2025 . . . 37
9.2 Hallazgos y recomendaciones . . . 38
9.3 Código sugerido . . . 39
10. Instalación, configuración y despliegue . . . 40
10.1 Requisitos del servidor . . . 40
10.2 Instalación en XAMPP (entorno local) . . . 40
10.3 Archivo .env . . . 40

10.4 Creación de administradores . . . 40
10.5 Despliegue en producción (lista de verificación) . . . 41
11. Plan y resultados de pruebas . . . 41
11.1 Estrategia . . . 41
11.2 Pruebas de compatibilidad . . . 43
12. Mantenimiento . . . 43
12.1 Control de versiones . . . 43
12.2 Hoja de ruta (visión a futuro SENA) . . . 44
Anexo A. Código fuente . . . 46
A. inicio/sesion.php . . . 46
A. inicio/login.php . . . 47
A. inicio/logout.php . . . 48
A. inicio/tema.php . . . 49
A. inicio/tema-json.php . . . 50
A. inicio/imagenes-editor.php . . . 50
A. contacto/formulario-contacto.php . . . 52
A. inicio/index-formulario.php (lógica del servidor, líneas 1–184) . . . 53
A. productos/productos-formulario.php (lógica del servidor, líneas 1–156) . . . 56
A. contacto/contactos-formulario.php (lógica del servidor, líneas 1–70) . . . 59
A. inicio/index.php (lógica del servidor, líneas 1–69) . . . 60
A. productos/productos.php (lógica del servidor, líneas 1–26) . . . 61
A. contacto/contactos.php (lógica del servidor, líneas 1–28) . . . 61
A. inicio/tema.js . . . 62

1. Introducción

1.1 Propósito

Este documento describe la construcción interna del Aplicativo Web "Pizzería Julián": normas que lo rigen, requisitos, arquitectura, modelos UML, base de datos, código fuente, seguridad, pruebas, instalación y mantenimiento. Su objetivo es que cualquier desarrollador pueda comprender, instalar, mantener y evolucionar el software sin depender de su autor. La estructura sigue las recomendaciones de ISO/IEC/IEEE 15289 (contenido de los elementos de información del ciclo de vida) e ISO/IEC/IEEE 26514 (documentación de software).

1.2 Alcance del sistema

El aplicativo es un sitio web de tipo informativo y promocional para una pizzería, con tres páginas públicas (Inicio, Productos y Contacto) y tres editores de contenido protegidos por inicio de sesión, que permiten al administrador modificar sin programar: el banner y la paleta de colores del sitio, el carrusel, el video, los textos promocionales, el número de WhatsApp, las tarjetas del catálogo y el mapa de ubicación. Incluye un formulario de contacto que guarda los mensajes en la base de datos y los envía por correo electrónico.

Fuera del alcance de la versión 1.0: carrito de compras, pagos en línea, registro de clientes, gestión de pedidos, gestión de usuarios desde la interfaz y lectura de mensajes desde los editores. Estas funciones forman parte de la visión a futuro del proyecto (tienda virtual inteligente).

1.3 Definiciones y siglas

Término	Definición
CRUD	Create, Read, Update, Delete: operaciones básicas sobre datos.
CSRF	Cross-Site Request Forgery: falsificación de peticiones entre sitios.
XSS	Cross-Site Scripting: inyección de código JavaScript en páginas.
PRG	Post/Redirect/Get: patrón que redirige tras un POST para evitar reenvíos del formulario.
DDL / DML	Lenguaje de definición / manipulación de datos (SQL).
PK / AI	Llave primaria / autoincremental.
bcrypt	Algoritmo de hash adaptativo usado por `password_hash()` de PHP.
SMTP	Protocolo de envío de correo electrónico.
UML	Unified Modeling Language (OMG UML 2.5.1).
XAMPP	Distribución que integra Apache, MariaDB, PHP y phpMyAdmin.

1.4 Referencias

- Manual de Usuario del Aplicativo Web "Pizzería Julián", v1.0.
- Código fuente del proyecto `pizza-julian` y respaldo de base de datos `bd/tecnico-2026-pagina.sql`.
- Normas y documentos listados en el capítulo 2.

2. Marco normativo y estándares aplicables

La siguiente tabla reúne las normas técnicas, estándares de la industria y disposiciones legales colombianas vigentes a octubre de 2026 que aplican al desarrollo, documentación, seguridad y operación del aplicativo, junto con el grado de cumplimiento verificado en el código.

2.1 Normas de ingeniería y calidad de software

Norma	Objeto	Aplicación en el proyecto
ISO/IEC/IEEE 12207:2017	Procesos del ciclo de vida del software.	Organización del desarrollo en análisis, diseño, construcción, pruebas, despliegue y mantenimiento (capítulos 4 a 12).
ISO/IEC/IEEE 29148:2018	Ingeniería de requisitos.	Especificación de requisitos funcionales y no funcionales con identificador, prioridad y criterio de verificación (cap. 4).
ISO/IEC/IEEE 42010:2022	Descripción de arquitectura.	Vistas de contexto, componentes, despliegue y datos (cap. 5 y 6).
ISO/IEC 25010:2023	Modelo de calidad del producto (SQuaRE): adecuación funcional, eficiencia, compatibilidad, capacidad de interacción, fiabilidad, seguridad, mantenibilidad, flexibilidad y protección (safety).	Evaluación de calidad (numeral 2.5) y requisitos no funcionales.
ISO/IEC 25012:2008	Modelo de calidad de datos.	Integridad y consistencia de datos (cap. 7).
ISO/IEC/IEEE 29119 (partes 1–5)	Pruebas de software.	Diseño y documentación de casos de prueba (cap. 11).
ISO/IEC/IEEE 15289:2019	Contenido de la documentación del ciclo de vida.	Estructura de este manual técnico.
ISO/IEC/IEEE 26514:2022	Diseño y desarrollo de documentación para usuarios.	Manual de Usuario y secciones de operación de este manual.
OMG UML 2.5.1 (ISO/IEC 19505)	Lenguaje Unificado de Modelado.	Diagramas de casos de uso, clases, componentes, despliegue, secuencia, actividad y estados (cap. 6).
ISO/IEC 9075 (SQL)	Lenguaje de base de datos SQL.	Scripts DDL y consultas (cap. 7).

Tabla 1. Normas de ingeniería y calidad de software.

2.2 Seguridad de la información

Norma / guía	Objeto	Aplicación
ISO/IEC 27001:2022 y 27002:2022	Sistema de gestión y controles de seguridad de la información.	Controles de acceso, criptografía, desarrollo seguro (8.25–8.28), gestión de vulnerabilidades y copias de respaldo.
OWASP Top 10:2025	Riesgos más críticos de aplicaciones web.	Matriz de riesgos y controles del capítulo 9.
OWASP ASVS 5.0	Requisitos verificables de seguridad de aplicaciones.	Lista de verificación de autenticación, sesión, validación y archivos.
OWASP Cheat Sheets	Buenas prácticas (CSRF, sesiones, subida de archivos, contraseñas).	Implementación de `sesion.php`, `login.php` e `imagenes-editor.php`.

Tabla 2. Normas de seguridad.

2.3 Accesibilidad y estándares web

Estándar	Objeto	Aplicación
W3C WCAG 2.2 (nivel AA)	Accesibilidad del contenido web.	Contraste de colores (la paleta se calcula con luminancia relativa WCAG), textos alternativos, idioma de la página, navegación por teclado.
NTC 5854 / Resolución MinTIC 1519 de 2020	Accesibilidad web en Colombia (obligatoria para sujetos obligados por la Ley 1712 de 2014).	Referente de buenas prácticas para el sitio.
HTML Living Standard (WHATWG), CSS, ECMAScript	Lenguajes del cliente.	Marcado semántico, Bootstrap 5.3.8 y JavaScript sin dependencias adicionales.
RFC 9110 (HTTP), RFC 6265 (cookies), RFC 5321 (SMTP)	Protocolos de comunicación.	Códigos de estado (303, 403, 422, 429), cookies HttpOnly/SameSite, envío de correo.

Tabla 3. Estándares de accesibilidad y web.

2.4 Estándares de codificación

Estándar	Aplicación
PHP-FIG PSR-12 / PER Coding Style	Estilo del código PHP: indentación de 4 espacios, llaves, declaración de tipos, una sentencia por línea.
PSR-4 (Composer)	Carga automática de PHPMailer mediante `vendor/autoload.php`.
Tipado estricto PHP	`declare(strict_types=1)` y tipos de parámetros y retorno en las funciones.
Convención de nombres del proyecto	Funciones y variables en español con camelCase (`guardarImagenSubida`); constantes en MAYÚSCULAS; columnas SQL en snake_case.
Comentarios	Comentarios en español que explican el porqué de cada control de seguridad.

Tabla 4. Estándares de codificación.

2.5 Legislación colombiana aplicable

Norma	Contenido	Implicación para el aplicativo
Ley 1581 de 2012 y Decreto 1377 de 2013 (compilado en el Decreto Único 1074 de 2015)	Régimen general de protección de datos personales (habeas data).	El formulario de contacto recolecta nombre, correo y teléfono: se requiere aviso de privacidad, autorización del titular y política de tratamiento.
Ley 1266 de 2008	Habeas data financiero.	No aplica en la versión actual (no se manejan datos financieros).
Ley 1273 de 2009	Delitos informáticos (acceso abusivo, violación de datos personales).	Fundamenta los controles de acceso y la protección de credenciales.
Ley 527 de 1999	Comercio electrónico y mensajes de datos.	Validez de los mensajes enviados por el formulario y de futuras transacciones en línea.
Ley 1480 de 2011	Estatuto del Consumidor (información y comercio electrónico).	Información veraz de productos y precios; aplicable plenamente al evolucionar a tienda virtual.
Ley 23 de 1982, Decisión Andina 351 de 1993 y Decreto 1360 de 1989	Derechos de autor; el software se protege como obra literaria.	Registro del software ante la Dirección Nacional de Derecho de Autor y respeto de licencias de terceros (Bootstrap y PHPMailer: licencias MIT y LGPL 2.1).
Ley 1712 de 2014	Transparencia y acceso a la información pública.	Referente si el sitio se publica en nombre de una entidad pública o educativa oficial.

Tabla 5. Legislación colombiana aplicable.

> **NOTA**
> A octubre de 2026 cursa en el Congreso un proyecto de ley para actualizar el régimen de protección de datos personales (Ley 1581 de 2012). Mientras no sea aprobado, la Ley 1581 de 2012 y sus decretos reglamentarios siguen vigentes.

2.6 Evaluación de calidad según ISO/IEC 25010:2023

Característica	Evidencia en el aplicativo	Valoración
Adecuación funcional	Los 12 casos de uso definidos están implementados; 23 de 25 pruebas aprobadas.	Alta
Eficiencia de desempeño	Páginas generadas en el servidor con una consulta por página; imágenes de banner de hasta 2,7 MB sin optimizar.	Media
Compatibilidad	Bootstrap 5.3.8 responsive; coexiste con servicios externos (YouTube, Maps, WhatsApp).	Alta
Capacidad de interacción (usabilidad)	Editores visuales con vista previa; avisos claros. Atributo `lang="en"` en páginas en español y textos alternativos genéricos.	Media-alta
Fiabilidad	Patrón PRG, transacción lógica de imágenes (descarte si falla). Error 500 si el teléfono del contacto está vacío.	Media

Característica	Evidencia en el aplicativo	Valoración
Seguridad	CSRF, consultas preparadas, bcrypt, bloqueo de intentos, validación MIME, escape de salida. Credenciales de BD embebidas y archivo .zip con .env en la raíz web.	Media
Mantenibilidad	Librerías compartidas y funciones tipadas; conexión a BD repetida en 9 archivos y lógica de login duplicada en 3 páginas.	Media
Flexibilidad (portabilidad)	Funciona en XAMPP y en cualquier hosting con PHP ≥ 8.1 y MariaDB/MySQL.	Alta
Protección (safety)	No aplica riesgo físico; los datos personales requieren política de tratamiento.	N/A

Tabla 6. Evaluación de calidad del producto.

3. Descripción general del sistema

3.1 Contexto

El aplicativo se ejecuta en un servidor Apache con PHP y una base de datos MariaDB (paquete XAMPP). Los visitantes acceden desde cualquier navegador; el administrador se autentica desde las mismas páginas públicas mediante una ventana modal y, una vez autenticado, trabaja en los editores. El sitio se integra con servicios externos: YouTube (video), Google Maps (mapa), WhatsApp (wa.me), Gmail SMTP (correo) y jsDelivr (íconos).

3.2 Tecnologías y versiones

Componente	Versión en el proyecto	Uso	Observación de soporte (oct. 2026)
PHP	8.2.12 (XAMPP)	Lógica del servidor	Rama 8.2 solo con parches de seguridad hasta el 31/12/2026. Planear migración a PHP 8.4 o 8.5.
MariaDB	10.4.32	Base de datos	Rama 10.4 fuera de soporte del proveedor; usar 10.11 LTS u 11.4 LTS en producción.
Apache HTTP Server	incluido en XAMPP	Servidor web	Mantener actualizado.
Bootstrap	5.3.8 (local)	Diseño responsive, modales, carruseles, acordeón	Vigente.
Bootstrap Icons	1.11.3 (CDN jsDelivr)	Íconos	Recomendado servir localmente o con SRI.
PHPMailer	7.1.1 (Composer)	Envío SMTP	Vigente; actualizar con `composer update`.
phpMyAdmin	5.2.1	Administración de BD	Restringir a localhost.
JavaScript	ES2015+ sin frameworks	Modales, vista previa, paleta de colores	—

Tabla 7. Pila tecnológica.

3.3 Perfiles de usuario

Perfil	Descripción	Acceso
Visitante	Cliente o público general.	Páginas públicas, formulario de contacto, WhatsApp.
Administrador	Persona de la pizzería encargada del contenido. Registrada en la tabla `usuario`.	Editores de Inicio, Productos y Contacto; phpMyAdmin.
Desarrollador / soporte	Mantiene el código y la infraestructura.	Código fuente, servidor, base de datos, archivo `.env`.

3.4 Restricciones y supuestos

- El sitio funciona con un único registro de contenido de Inicio (el primero de la tabla `inicio`) que define también el banner y la paleta de todo el sitio.
- Las imágenes se almacenan en el sistema de archivos (`img-inicio/`, `img-productos/`) y en la base de datos solo se guarda su ruta.
- El envío de correo requiere una cuenta de Gmail con verificación en dos pasos y una contraseña de aplicación.
- Se requiere conexión a internet para video, mapa, íconos y correo.

4. Especificación de requisitos

4.1 Requisitos funcionales

ID	Requisito	Prioridad	Implementación
RF01	Mostrar la página de Inicio con banner, carrusel de 3 imágenes, video de YouTube, acordeón de 5 elementos y 3 secciones desplegables.	Alta	`inicio/index.php`
RF02	Mostrar el catálogo de productos en tarjetas de 4 por fila, cada una con carrusel de 3 imágenes.	Alta	`productos/productos.php`
RF03	Mostrar el mapa de ubicación y el formulario de contacto.	Alta	`contacto/contactos.php`
RF04	Registrar los mensajes de contacto en la base de datos y enviarlos por correo.	Alta	`contacto/formulario-contacto.php`
RF05	Abrir WhatsApp con un mensaje predefinido desde un botón flotante.	Media	Enlace `wa.me`
RF06	Autenticar al administrador con usuario y contraseña desde una ventana modal con límite de 30 s.	Alta	`inicio/login.php`
RF07	Bloquear el inicio de sesión 5 minutos tras 5 intentos fallidos.	Alta	`inicio/login.php`
RF08	Crear, editar y eliminar el contenido de Inicio, incluido el número de WhatsApp.	Alta	`inicio/index-formulario.php`
RF09	Calcular la paleta de colores del sitio a partir del banner y aplicarla a todas las páginas, incluso las abiertas en otras pestañas.	Media	`tema.js`, `tema.php`, `tema-json.php`

ID	Requisito	Prioridad	Implementación
RF10	Crear, editar y eliminar productos con 3 imágenes obligatorias.	Alta	`productos/productos-formulario.php`
RF11	Crear y editar la URL del mapa de Google.	Media	`contacto/contactos-formulario.php`
RF12	Validar las imágenes por su contenido real (JPG, PNG, GIF, WEBP) y tamaño máximo de 5 MB.	Alta	`inicio/imagenes-editor.php`
RF13	Eliminar del servidor las imágenes reemplazadas o de registros borrados que ya no se usen.	Media	`eliminarImagenesReemplazadas()`
RF14	Cerrar sesión de forma segura y devolver al usuario a la página pública correspondiente.	Alta	`inicio/logout.php`
RF15	Impedir el acceso a los editores sin sesión iniciada.	Alta	`usuarioAutenticado()`

Tabla 8. Requisitos funcionales.

4.2 Requisitos no funcionales

ID	Categoría (ISO 25010)	Requisito	Verificación
RNF01	Seguridad	Todas las consultas con datos del usuario usan sentencias preparadas.	Revisión de código; prueba P07.
RNF02	Seguridad	Contraseñas almacenadas con bcrypt (`password_hash`).	Revisión de la tabla usuario.
RNF03	Seguridad	Toda acción que cambia datos exige token CSRF de 256 bits.	Pruebas P06, P13, P21.
RNF04	Seguridad	Cookie de sesión HttpOnly, SameSite=Lax y Secure bajo HTTPS.	Prueba P23.
RNF05	Seguridad	Salida HTML escapada con `htmlspecialchars`.	Prueba P17.
RNF06	Capacidad de interacción	Diseño adaptable a celular, tableta y computador.	Capturas del Manual de Usuario.
RNF07	Fiabilidad	Patrón PRG en todos los editores para evitar reenvíos.	Respuestas 303 en P13–P18.
RNF08	Mantenibilidad	Código PHP con tipado estricto y funciones reutilizables.	Revisión de código.
RNF09	Eficiencia	Tiempo de respuesta de las páginas menor a 1 s en red local.	Medición en pruebas.
RNF10	Flexibilidad	Ejecución en PHP ≥ 8.1 y MariaDB/MySQL sin cambios de código.	Pruebas en PHP 8.3 / MariaDB 10.11.

Tabla 9. Requisitos no funcionales.

5. Arquitectura del software

5.1 Estilo arquitectónico

El aplicativo sigue una arquitectura **cliente-servidor de tres capas** con renderizado en el servidor y el patrón **Page Controller**: cada archivo PHP atiende una página, procesa sus peticiones POST, consulta la base de datos y genera el HTML. La lógica transversal se aísla en tres librerías compartidas (`sesion.php`, `tema.php`, `imagenes-editor.php`). En el cliente, JavaScript se usa de forma progresiva para el inicio de sesión asíncrono (fetch/JSON), la vista previa de imágenes y la paleta dinámica de colores.

Capa	Responsabilidad	Elementos
Presentación	Interfaz HTML/CSS responsive, modales, validación en el cliente.	Bootstrap 5.3.8, `*.css`, `tema.js`, scripts de cada página.
Lógica de negocio / control	Autenticación, autorización, validación, CRUD, carga de archivos, envío de correo.	Archivos PHP de cada módulo y librerías compartidas.
Datos	Persistencia de contenido, productos, mensajes y usuarios; archivos de imagen.	MariaDB `tecnico-2026-pagina`; carpetas `img-*`.

5.2 Estructura de carpetas

```
pizza-julian/
├── bd/
│   └── tecnico-2026-pagina.sql      Respaldo de la base de datos (DDL + datos)
├── bootstrap-5.3.8-dist/            Bootstrap local (css/ y js/)
├── inicio/
│   ├── index.php                    Página pública de Inicio
│   ├── index-formulario.php         Editor de Inicio (protegido)
│   ├── login.php                    Servicio JSON de autenticación
│   ├── logout.php                   Cierre de sesión
│   ├── sesion.php                   Librería: sesión segura y CSRF
│   ├── tema.php / tema.css          Librería: banner y paleta del sitio
│   ├── tema.js                      Cálculo y sincronización de la paleta
│   ├── tema-json.php                Servicio JSON del tema actual
│   ├── imagenes-editor.php          Librería: validación y gestión de imágenes
│   ├── inicio.css                   Estilos del módulo
│   └── img-inicio/                  Imágenes del banner y carrusel
├── productos/
│   ├── productos.php                Página pública de Productos
│   ├── productos-formulario.php     Editor de Productos (protegido)
│   ├── productos.css
│   └── img-productos/               Imágenes de los productos
└── contacto/
    ├── contactos.php                Página pública de Contacto
    ├── contactos-formulario.php     Editor de Contacto (protegido)
    ├── formulario-contacto.php      Procesa el formulario y envía el correo
    ├── contactos.css
    ├── composer.json / vendor/      Dependencia PHPMailer
    ├── .env                         Credenciales SMTP (no versionar)
    └── img-contactos/
```

Archivo	Líneas
Archivos PHP (11)	2.395
JavaScript propio (tema.js)	191

Archivo	Líneas
CSS propio (4 archivos)	2.014
SQL de respaldo	183
Total código propio	**≈ 5.160**

5.3 Vista de componentes

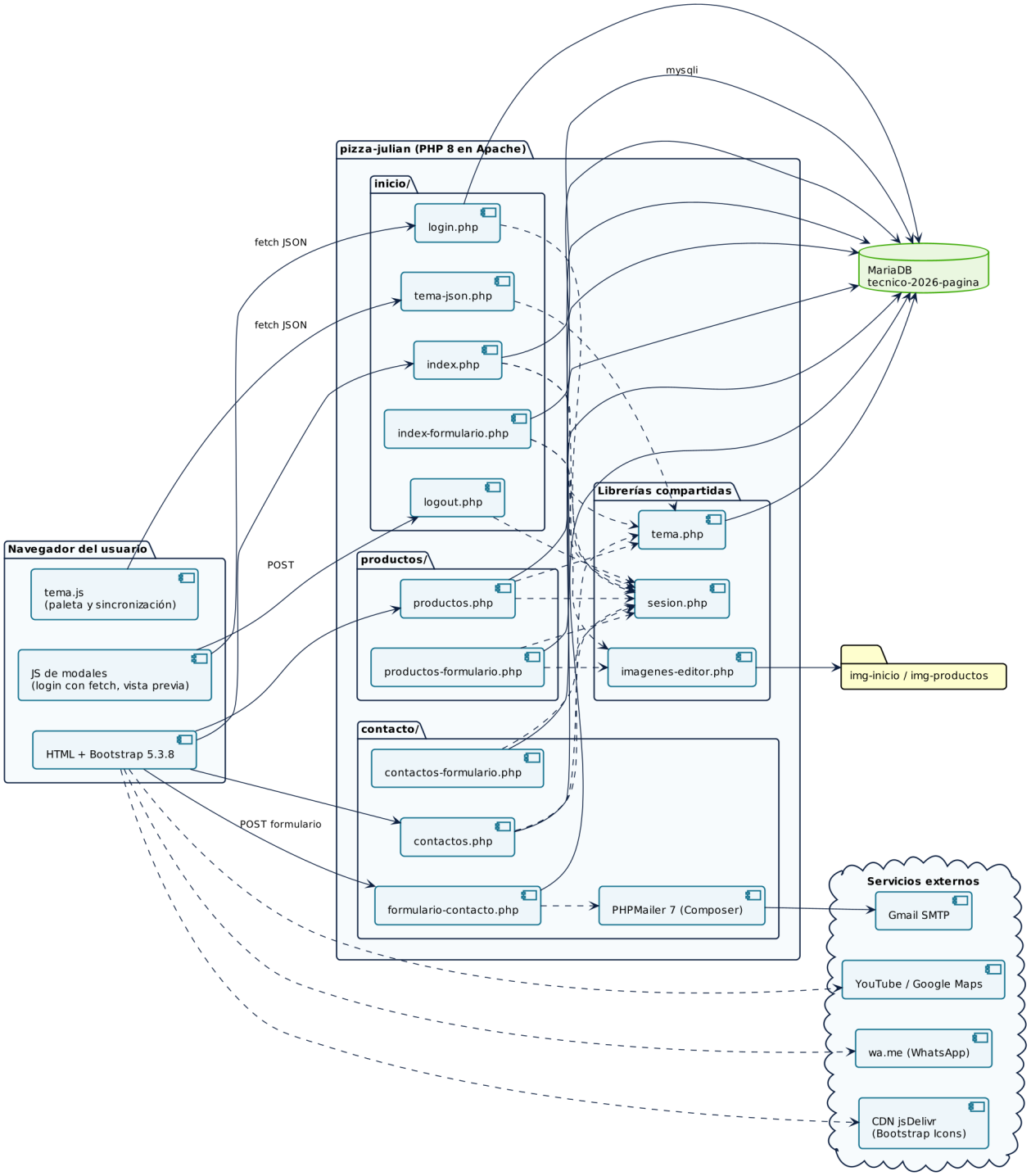


Figura 1. Diagrama de componentes del aplicativo.

5.4 Vista de despliegue

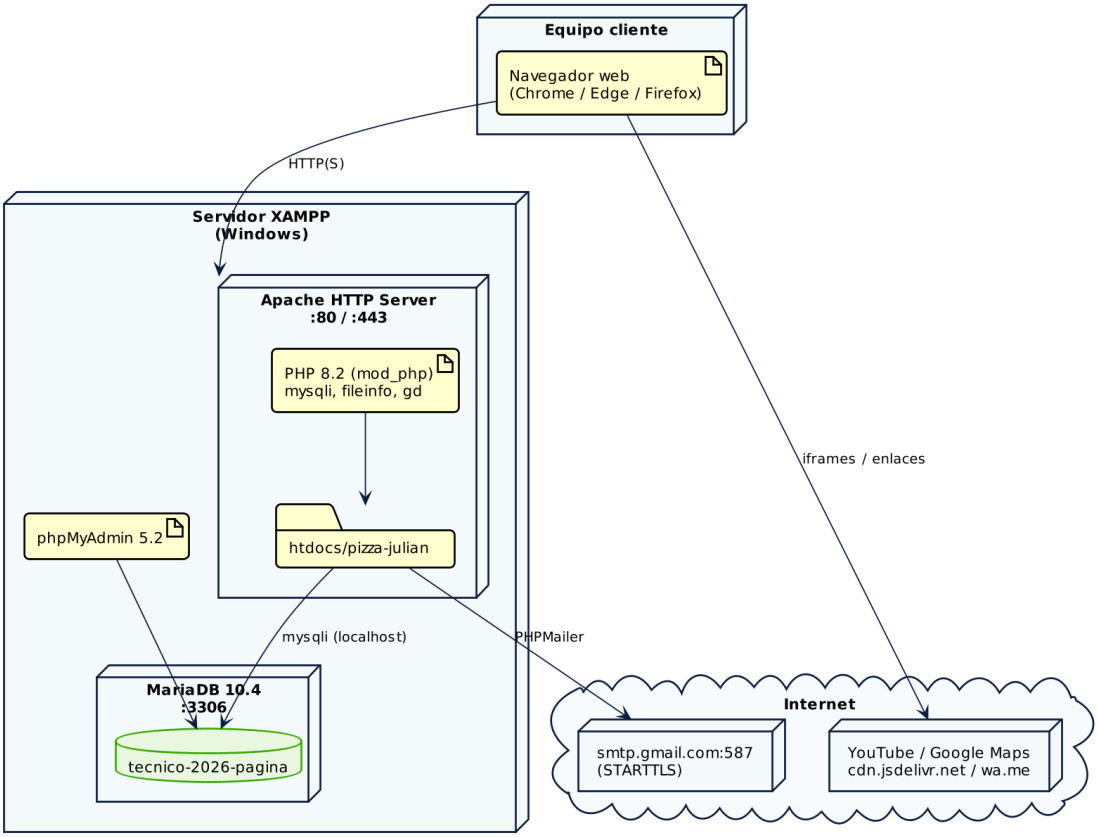


Figura 2. Diagrama de despliegue.

5.5 Patrones y decisiones de diseño

Decisión	Justificación
Page Controller por archivo	Simplicidad didáctica; cada página es autocontenida y fácil de ubicar.
Post/Redirect/Get (HTTP 303)	Evita reenvíos al recargar y permite mostrar mensajes con el parámetro `?estado=`.
Login asíncrono con fetch y JSON	Permite mostrar errores dentro del modal sin recargar la página.
Rutas de imagen en BD, archivos en disco	Base de datos liviana; imágenes servidas directamente por Apache.
Nombres de archivo con `uniqid()`	Evita colisiones y que el nombre original del usuario llegue al servidor.
Paleta calculada en el navegador	Se aprovecha Canvas del cliente; el servidor solo valida el JSON (formato #rrggbb).
Sincronización entre pestañas con localStorage	El evento `storage` notifica a otras pestañas que consulten `tema-json.php`.

6. Modelado UML

Los diagramas se elaboraron con la notación OMG UML 2.5.1 y describen la interacción del **usuario final (visitante)** y del **administrador** con el sistema.

6.1 Diagrama de casos de uso general

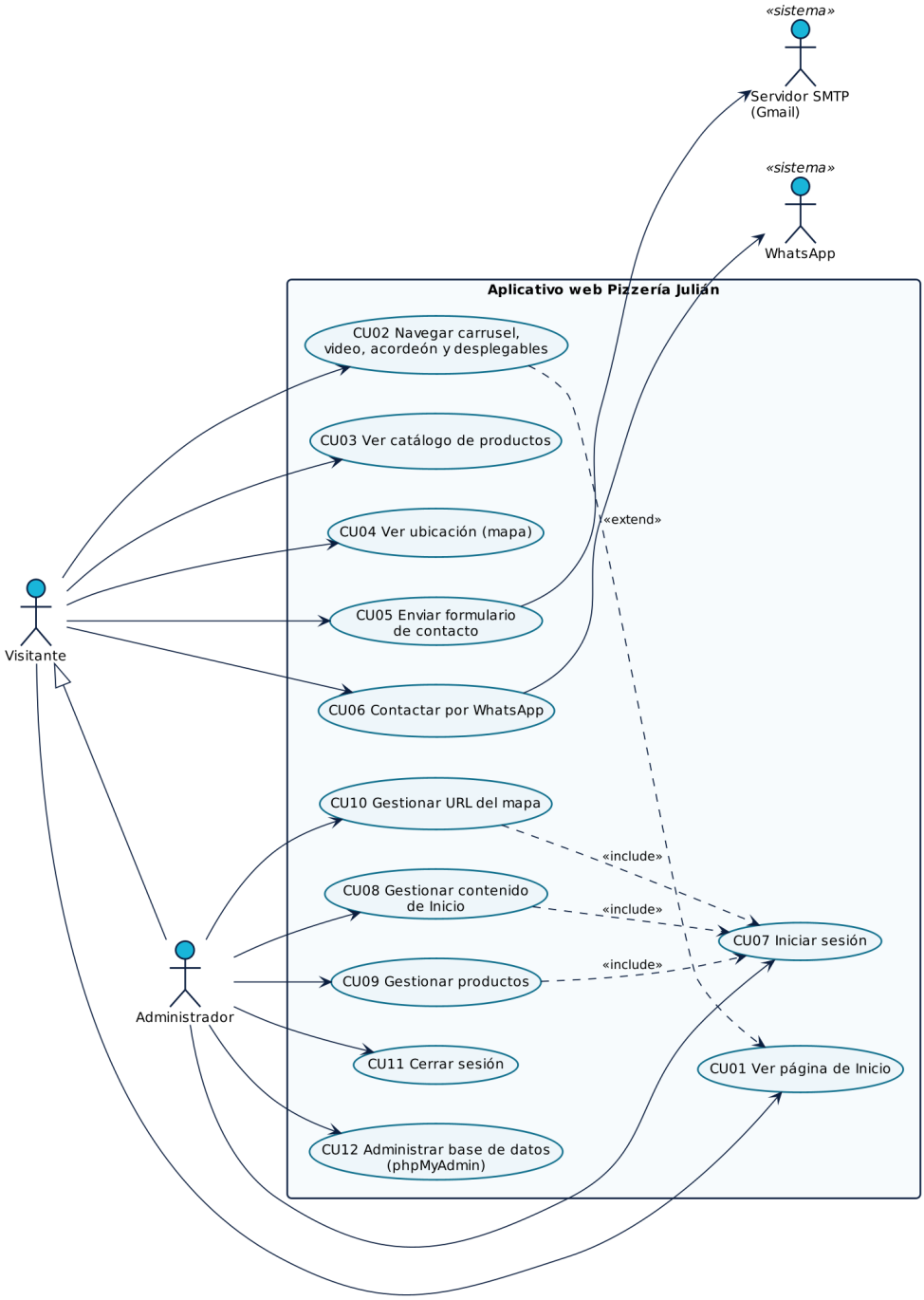


Figura 3. Diagrama de casos de uso general.

6.2 Diagrama de casos de uso del administrador

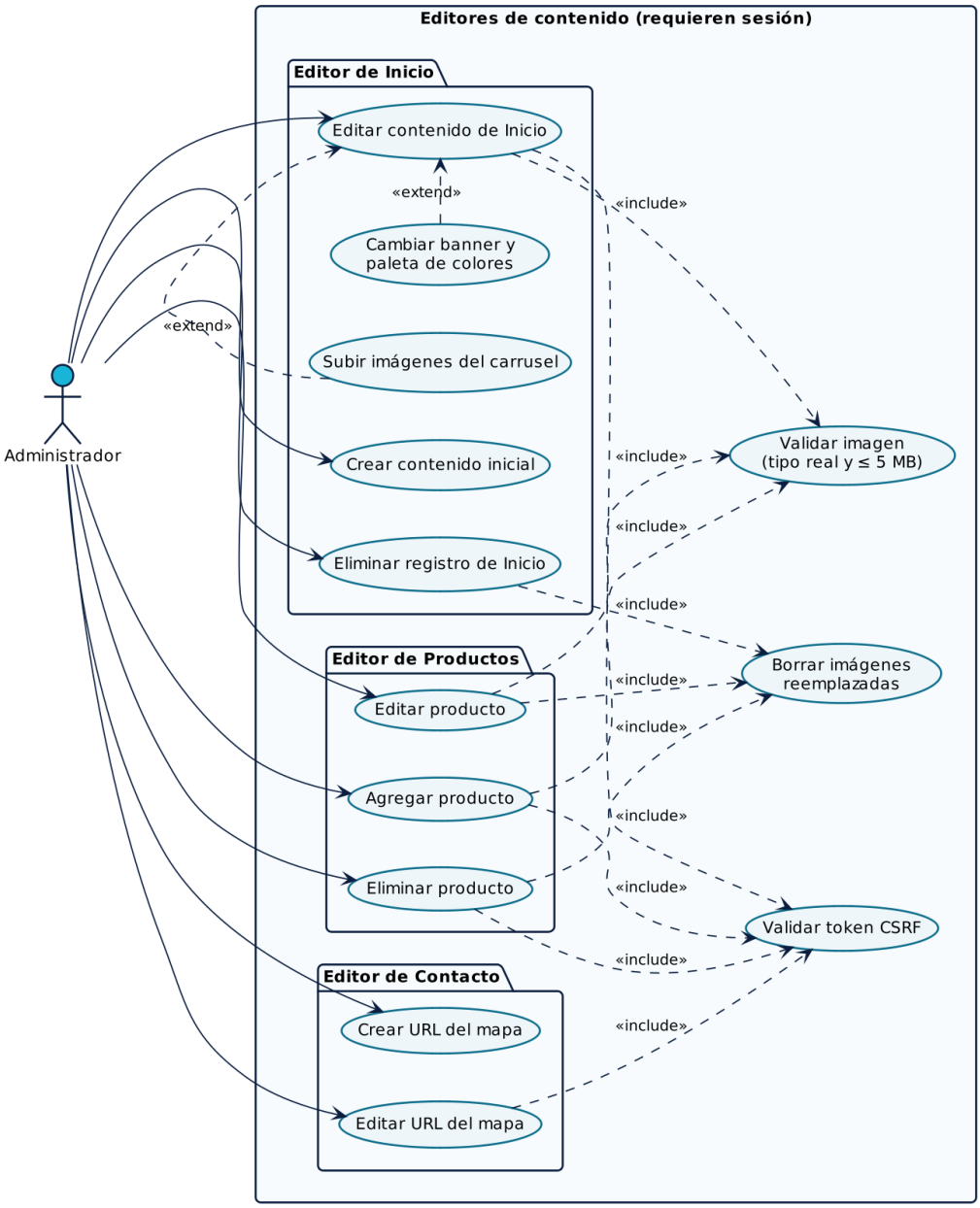


Figura 4. Casos de uso detallados de los editores de contenido.

6.3 Especificación de casos de uso

CU05 – Enviar formulario de contacto

Campo	Descripción
Actor	Visitante (principal); servidor SMTP Gmail (secundario).
Precondición	La página de Contacto está disponible.
Flujo básico	1. El visitante diligencia Email, Nombre, Teléfono y Comentario. 2. Pulsa Submit. 3. El sistema valida correo, nombre y mensaje. 4. Inserta el registro en `formulario-contacto`. 5. Envía el correo por SMTP con respuesta al visitante. 6. Redirige a `contactos.php?envio=ok` y muestra la confirmación.
Flujos alternos	3a. Datos inválidos: HTTP 422 con mensaje. 5a. Sin contraseña de aplicación: HTTP 500 "La información se guardó, pero el correo no está configurado". 5b. Error SMTP: HTTP 502.
Postcondición	Mensaje almacenado y notificado.

CU07 – Iniciar sesión

Campo	Descripción
Actor	Administrador.
Precondición	Usuario registrado en la tabla `usuario` con contraseña bcrypt.
Flujo básico	1. Pulsa Inicio Sesion. 2. El sistema abre el modal con contador de 30 s y token CSRF. 3. Digita usuario y contraseña. 4. El sistema valida el token, el bloqueo, los campos y la contraseña con `password_verify`. 5. Regenera el id de sesión, guarda `usuario_id` y redirige al editor de la página de origen.
Flujos alternos	2a. Se agotan los 30 s: se cierra el modal. 4a. Token inválido: 403. 4b. Bloqueo vigente: 429. 4c. Credenciales incorrectas: se incrementa el contador; al 5.º fallo se bloquea 300 s.
Postcondición	Sesión autenticada.

CU08 – Gestionar contenido de Inicio

Campo	Descripción
Actor	Administrador.
Precondición	Sesión iniciada (incluye CU07).
Flujo básico	1. Abre el Editor de Inicio. 2. Pulsa Editar. 3. Modifica imágenes, URL del video, textos y WhatsApp. 4. Si cambia el banner, el navegador calcula la paleta y la aplica como vista previa. 5. Pulsa Guardar. 6. El sistema valida CSRF e imágenes, actualiza el registro, borra las imágenes reemplazadas y muestra "Contenido actualizado correctamente". 7. Las pestañas abiertas aplican el nuevo tema.
Flujos alternos	6a. Imagen inválida: no se guarda nada y se descartan los archivos subidos. 1a. Tabla vacía: Crear contenido inicial. 2a. Eliminar con confirmación.
Postcondición	Contenido y tema del sitio actualizados.

CU09 – Gestionar productos

Campo	Descripción
Actor	Administrador.
Precondición	Sesión iniciada.
Flujo básico	1. Pulsa Agregar producto. 2. Selecciona 3 imágenes (validadas y previsualizadas en el cliente). 3. Escribe título, texto y texto del botón. 4. Guarda. 5. El sistema inserta el registro y muestra "Producto creado correctamente".
Flujos alternos	4a. Falta una imagen: `imagen_requerida`. 4b. Imagen inválida: `error_imagen`. Editar: conserva imágenes no reemplazadas. Eliminar: borra registro e imágenes sin uso.
Postcondición	Catálogo actualizado en `productos.php`.

CU10 – Gestionar URL del mapa

Campo	Descripción
Actor	Administrador.
Flujo básico	1. Abre el Editor de Contacto. 2. Pulsa Editar (o Crear URL del mapa). 3. Pega la URL embed de Google Maps (≤ 500 caracteres). 4. Guarda. 5. El sistema actualiza la tabla `contacto`.
Postcondición	Mapa actualizado en `contactos.php`.

6.4 Diagrama de clases (estructura del código)

PHP del proyecto es procedimental; el diagrama representa cada archivo como una clase estereotipada con sus funciones y constantes, y las dependencias (`require_once`) entre ellos.

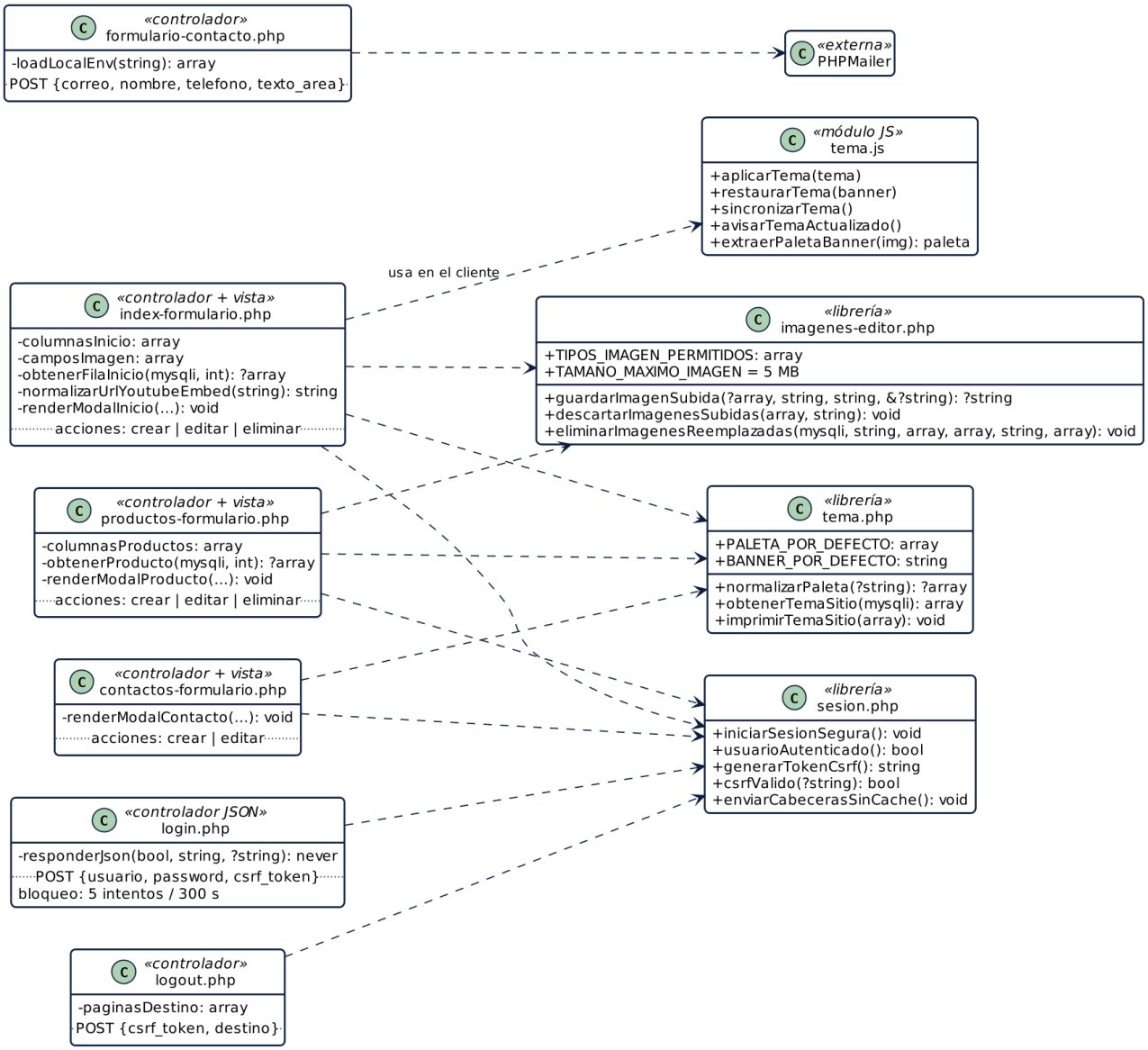


Figura 5. Diagrama de clases de los módulos del aplicativo.

6.5 Diagramas de secuencia

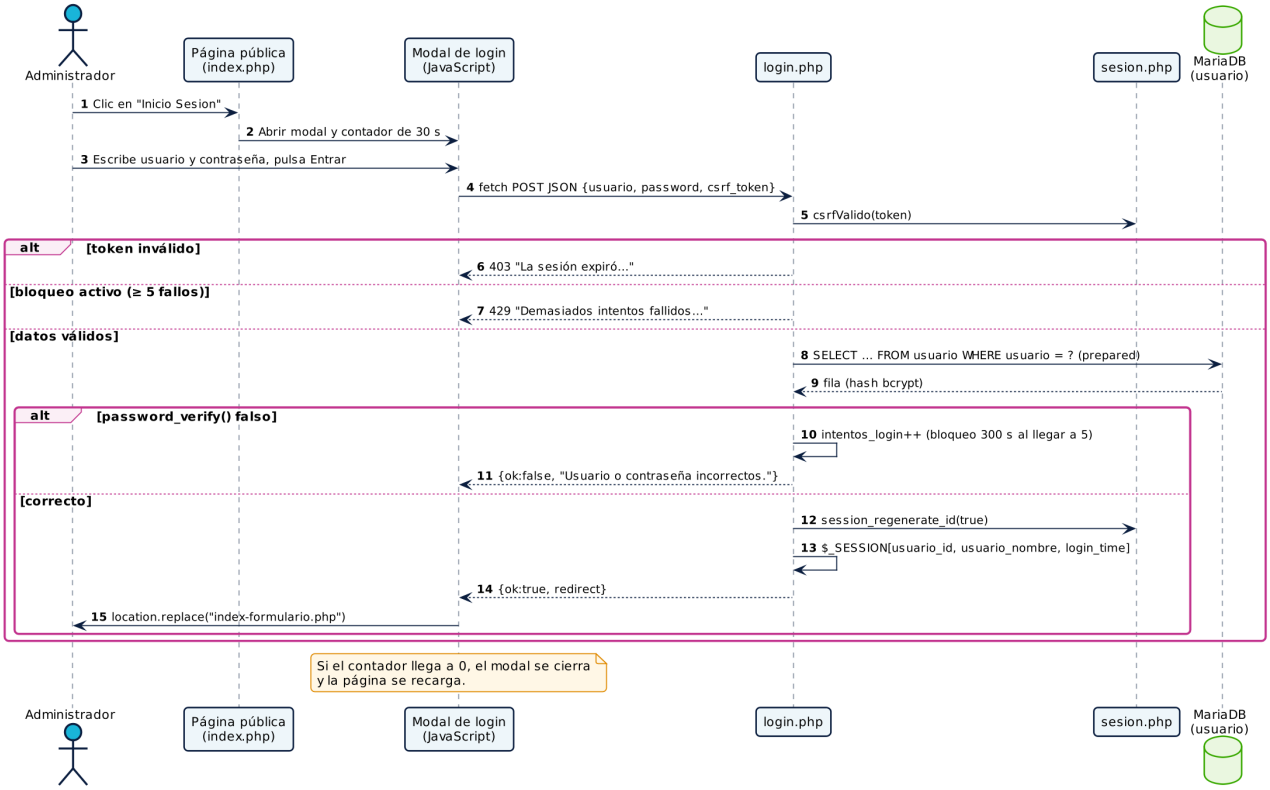


Figura 6. Secuencia: inicio de sesión del administrador.

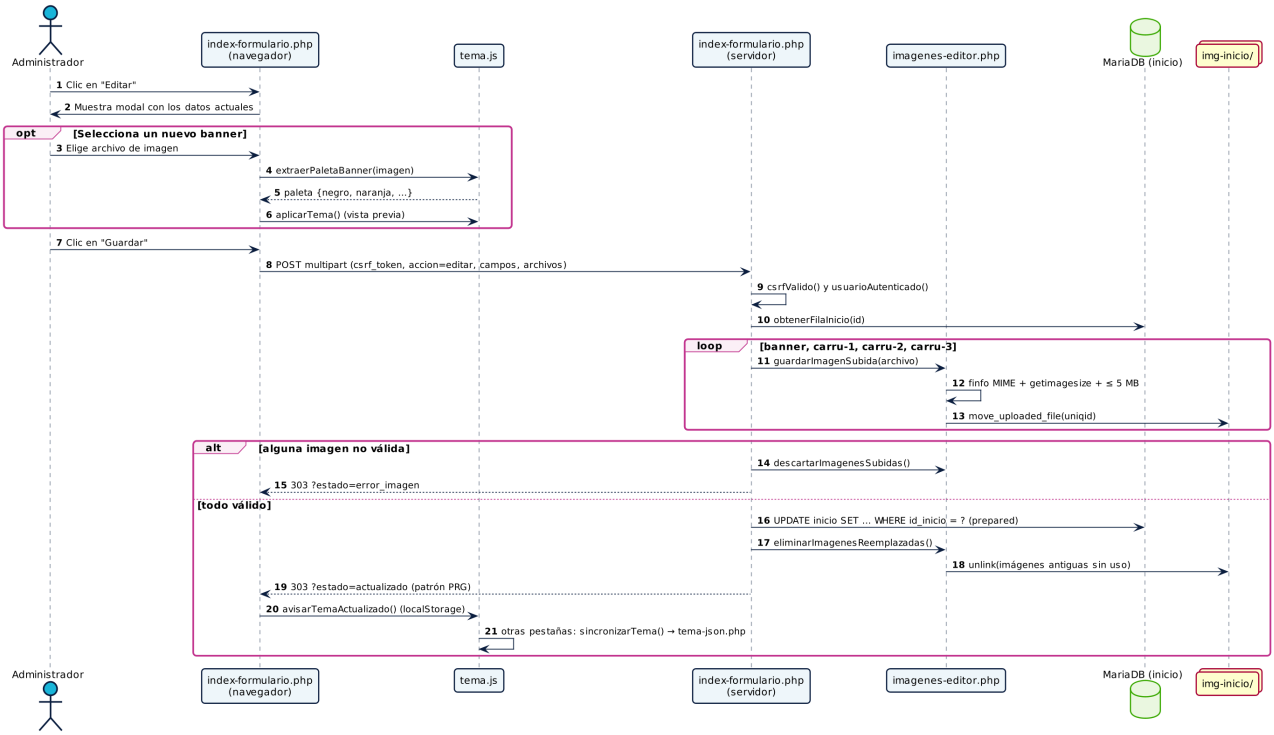


Figura 7. Secuencia: edición del contenido de Inicio con cambio de banner.

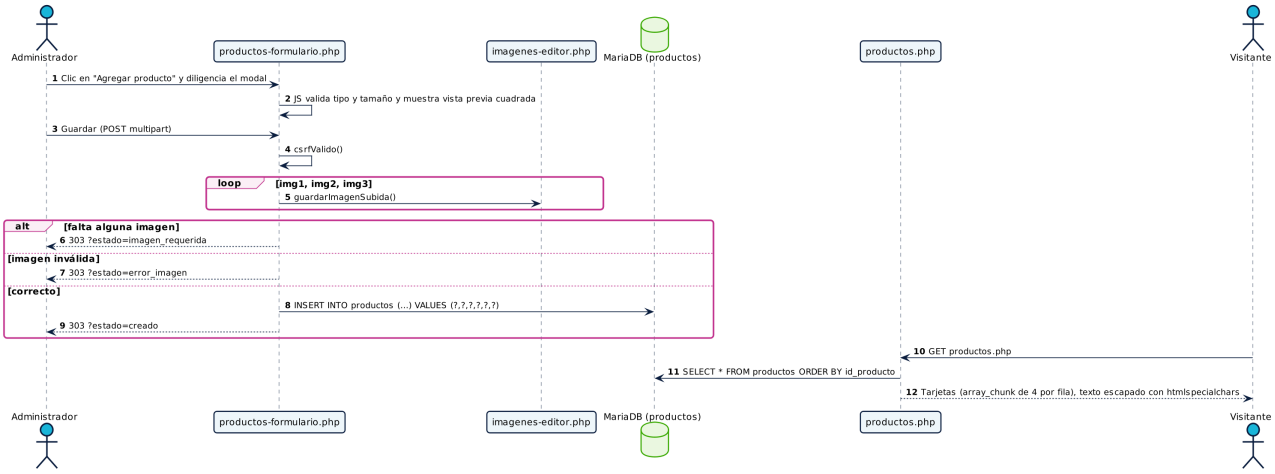


Figura 8. Secuencia: creación de un producto y consulta por el visitante.

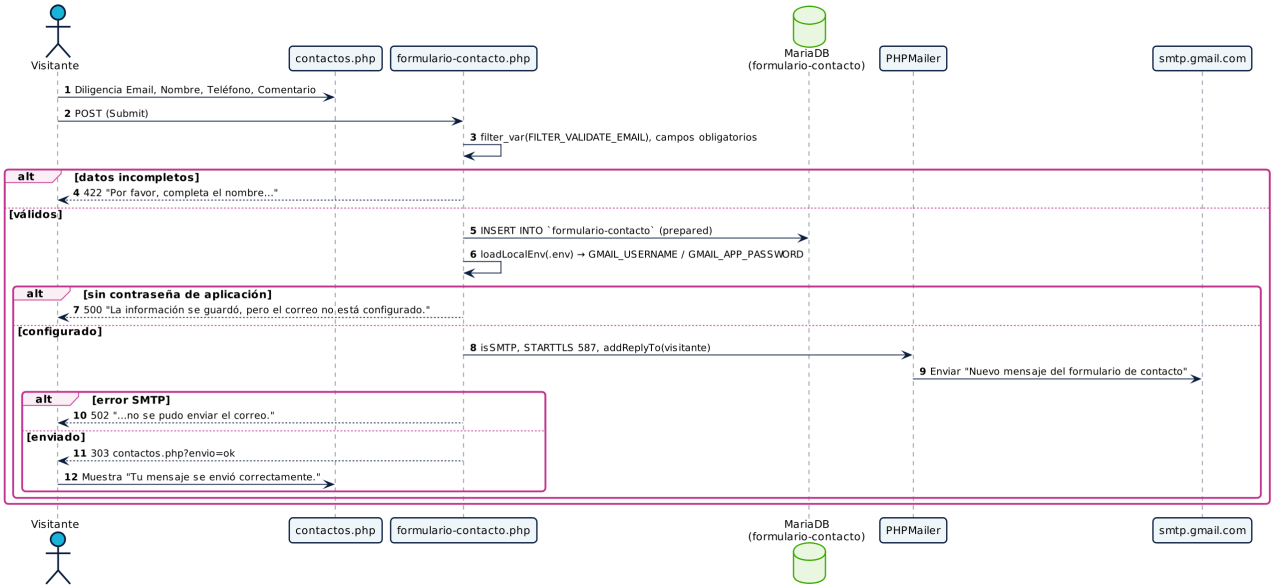


Figura 9. Secuencia: envío del formulario de contacto.

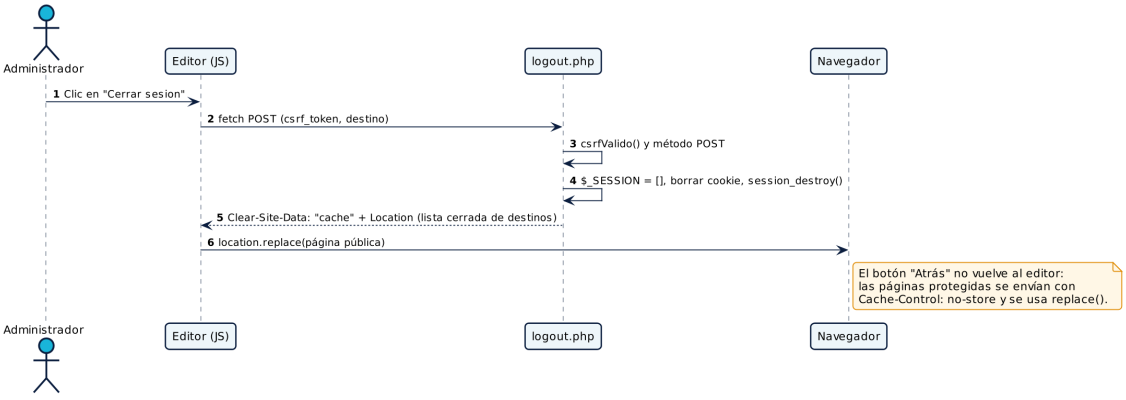


Figura 10. Secuencia: cierre de sesión.

6.6 Diagramas de actividad

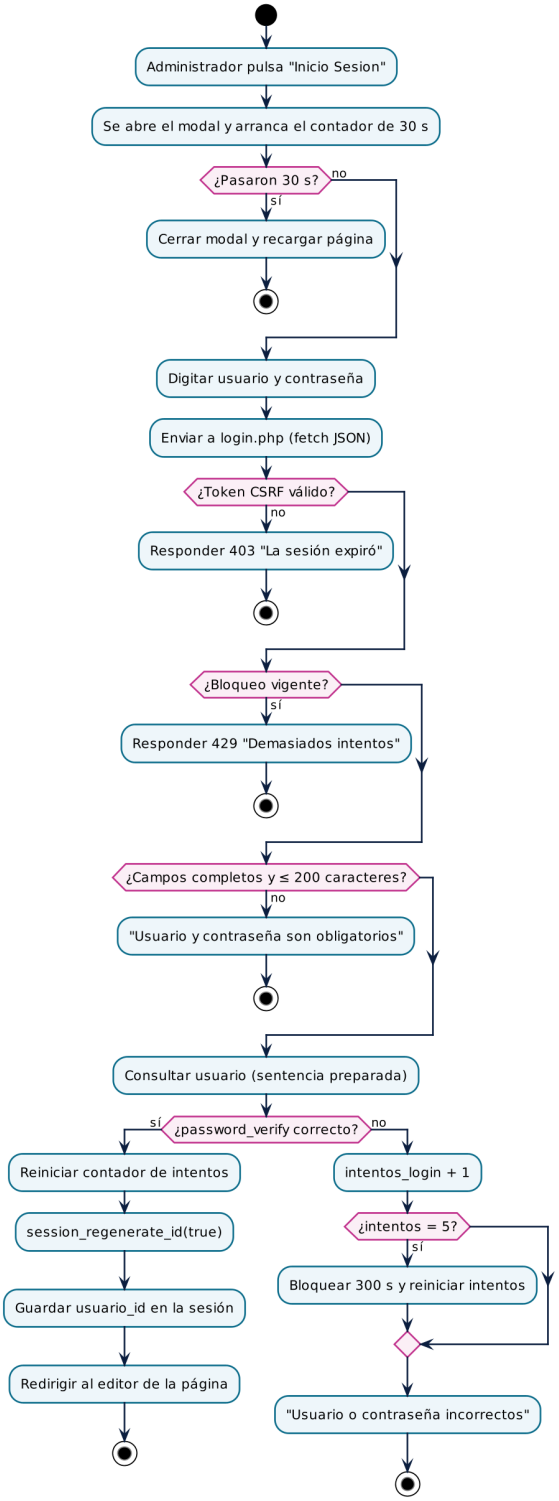


Figura 11. Actividad: proceso de inicio de sesión con bloqueo.

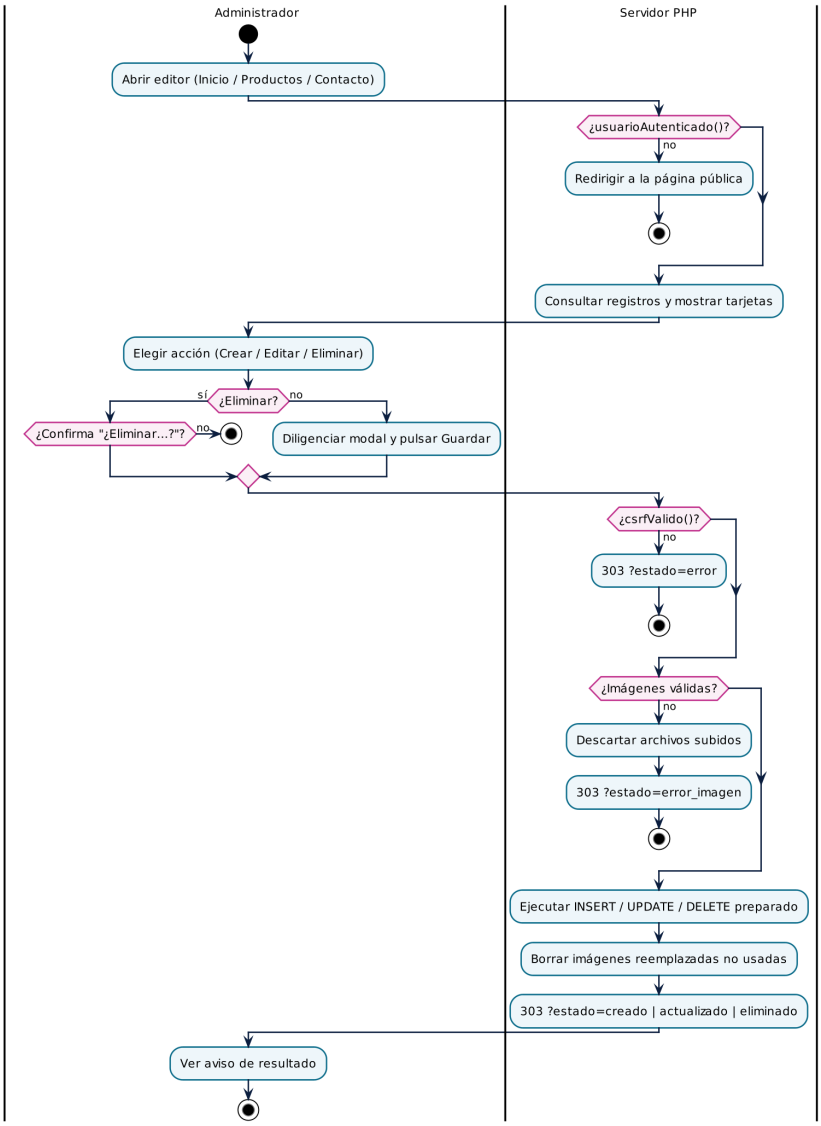


Figura 12. Actividad: operación CRUD en un editor (con particiones).

6.7 Diagrama de estados de la sesión

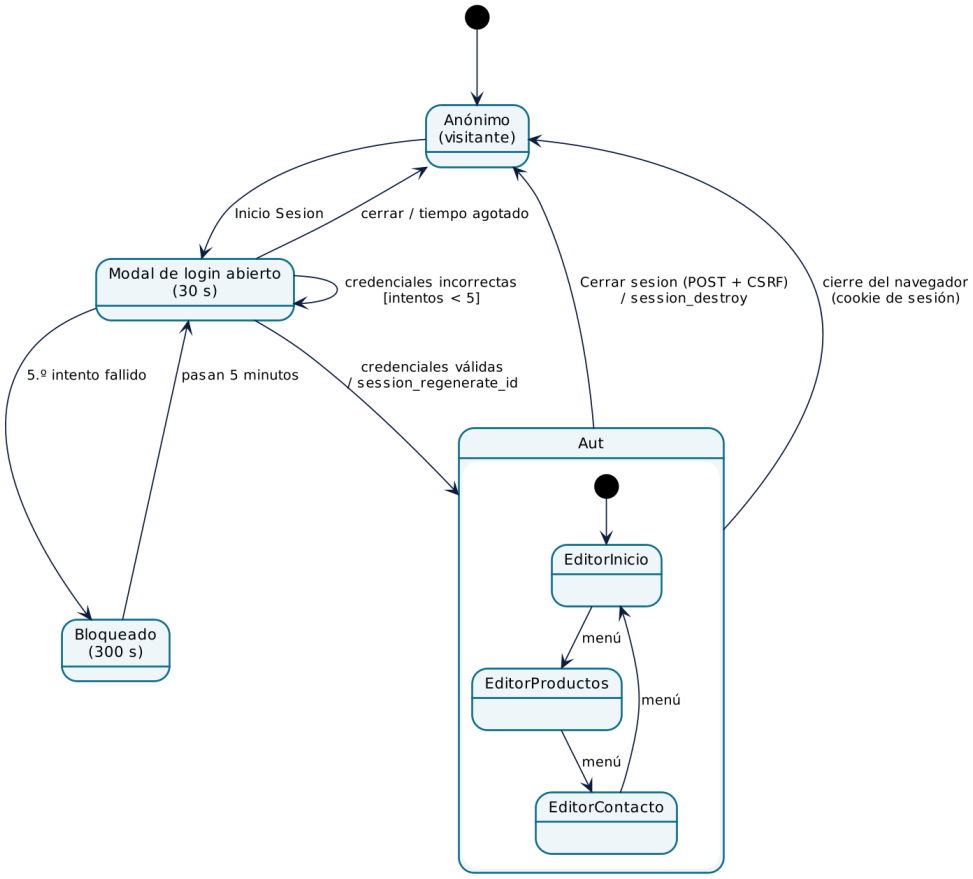


Figura 13. Máquina de estados de la sesión del administrador.

6.8 Diagrama de navegación

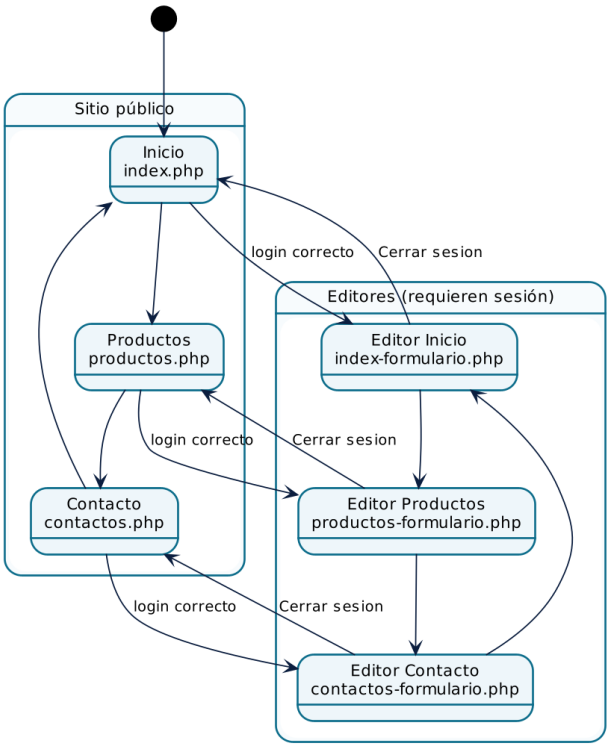


Figura 14. Navegación entre páginas públicas y editores.

7. Desarrollo de la base de datos

7.1 Características generales

Parámetro	Valor
Nombre	`tecnico-2026-pagina`
Motor	MariaDB 10.4.32 (compatible con MySQL 8), motor de almacenamiento InnoDB
Juego de caracteres / cotejamiento	`utf8` / `utf8_spanish2_ci`
Tablas	5: `inicio`, `productos`, `contacto`, `formulario-contacto`, `usuario`
Relaciones	No hay llaves foráneas: cada tabla es independiente (modelo de contenidos).
Acceso	Extensión `mysqli` de PHP; usuario `root` sin contraseña en el entorno local.

7.2 Modelo entidad-relación

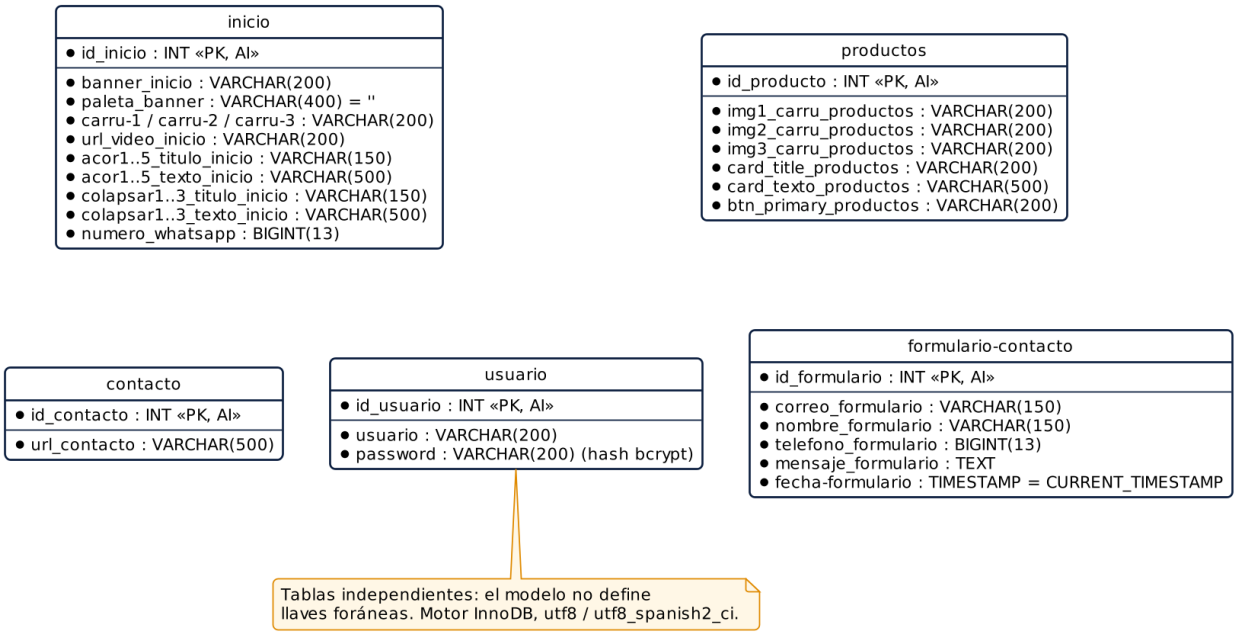


Figura 15. Modelo entidad-relación (físico) de la base de datos.

7.3 Diccionario de datos

Tabla	Campo	Tipo	Restricción	Descripción
inicio	id_inicio	INT(11)	PK, AI, NOT NULL	Identificador del registro de contenido.
	banner_inicio	VARCHAR(200)	NOT NULL	Ruta relativa de la imagen del banner (`./img-inicio/…`).
	paleta_banner	VARCHAR(400)	NOT NULL DEFAULT ''	JSON con 9 colores #rrggbb derivados del banner.
	carru-1, carru-2, carru-3	VARCHAR(200)	NOT NULL	Rutas de las imágenes del carrusel.
	url_video_inicio	VARCHAR(200)	NOT NULL	URL `youtube.com/embed/…`.
	acorN_titulo_inicio (N=1..5)	VARCHAR(150)	NOT NULL	Título del elemento N del acordeón.
	acorN_texto_inicio (N=1..5)	VARCHAR(500)	NOT NULL	Texto del elemento N del acordeón.
	colapsarN_titulo_inicio (N=1..3)	VARCHAR(150)	NOT NULL	Texto del botón desplegable N.
	colapsarN_texto_inicio (N=1..3)	VARCHAR(500)	NOT NULL	Contenido del desplegable N.
	numero_whatsapp	BIGINT(13)	NOT NULL	Número con indicativo de país (p. ej. 573132345685).

Tabla	Campo	Tipo	Restricción	Descripción
productos	id_producto	INT(11)	PK, AI	Identificador; define el orden de las tarjetas.
	img1/img2/img3_carru_productos	VARCHAR(200)	NOT NULL	Rutas de las 3 imágenes (`./img-productos/…`).
	card_title_productos	VARCHAR(200)	NOT NULL	Título de la tarjeta.
	card_texto_productos	VARCHAR(500)	NOT NULL	Descripción.
	btn_primary_productos	VARCHAR(200)	NOT NULL	Texto del botón.
contacto	id_contacto	INT(11)	PK, AI	Identificador.
	url_contacto	VARCHAR(500)	NOT NULL	URL embed de Google Maps.
formulario-contacto	id_formulario	INT(11)	PK, AI	Identificador del mensaje.
	correo_formulario	VARCHAR(150)	NOT NULL	Correo del visitante.
	nombre_formulario	VARCHAR(150)	NOT NULL	Nombre del visitante.
	telefono_formulario	BIGINT(13)	NOT NULL	Teléfono (ver hallazgo H05).
	mensaje_formulario	TEXT	NOT NULL	Mensaje.
	fecha-formulario	TIMESTAMP	DEFAULT CURRENT_TIMESTAMP ON UPDATE	Fecha de registro.
usuario	id_usuario	INT(11)	PK, AI	Identificador.
	usuario	VARCHAR(200)	NOT NULL	Nombre de inicio de sesión.
	password	VARCHAR(200)	NOT NULL	Hash bcrypt ($2y$10$…, 60 caracteres).

Tabla 10. Diccionario de datos.

7.4 Script DDL de creación

Script completo para crear la base de datos desde cero. Incluye la tabla `contacto`, que el archivo `bd/tecnico-2026-pagina.sql` no contiene.

```sql
CREATE DATABASE IF NOT EXISTS `tecnico-2026-pagina`
  DEFAULT CHARACTER SET utf8 COLLATE utf8_spanish2_ci;
USE `tecnico-2026-pagina`;

CREATE TABLE `inicio` (
  `id_inicio` int(11) NOT NULL AUTO_INCREMENT,
  `banner_inicio` varchar(200) NOT NULL,
  `paleta_banner` varchar(400) NOT NULL DEFAULT '',
  `carru-1` varchar(200) NOT NULL,
  `carru-2` varchar(200) NOT NULL,
  `carru-3` varchar(200) NOT NULL,
  `url_video_inicio` varchar(200) NOT NULL,
  `acor1_titulo_inicio` varchar(150) NOT NULL,  `acor1_texto_inicio` varchar(500) NOT NULL,
  `acor2_titulo_inicio` varchar(150) NOT NULL,  `acor2_texto_inicio` varchar(500) NOT NULL,
  `acor3_titulo_inicio` varchar(150) NOT NULL,  `acor3_texto_inicio` varchar(500) NOT NULL,
  `acor4_titulo_inicio` varchar(150) NOT NULL,  `acor4_texto_inicio` varchar(500) NOT NULL,
  `acor5_titulo_inicio` varchar(150) NOT NULL,  `acor5_texto_inicio` varchar(500) NOT NULL,
  `colapsar1_titulo_inicio` varchar(150) NOT NULL, `colapsar1_texto_inicio` varchar(500) NOT NULL,
  `colapsar2_titulo_inicio` varchar(150) NOT NULL, `colapsar2_texto_inicio` varchar(500) NOT NULL,
  `colapsar3_titulo_inicio` varchar(150) NOT NULL, `colapsar3_texto_inicio` varchar(500) NOT NULL,
  `numero_whatsapp` bigint(13) NOT NULL,
  PRIMARY KEY (`id_inicio`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8 COLLATE=utf8_spanish2_ci;

CREATE TABLE `productos` (
  `id_producto` int(11) NOT NULL AUTO_INCREMENT,
  `img1_carru_productos` varchar(200) NOT NULL,
  `img2_carru_productos` varchar(200) NOT NULL,
  `img3_carru_productos` varchar(200) NOT NULL,
  `card_title_productos` varchar(200) NOT NULL,
  `card_texto_productos` varchar(500) NOT NULL,
  `btn_primary_productos` varchar(200) NOT NULL,
  PRIMARY KEY (`id_producto`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8 COLLATE=utf8_spanish2_ci;

CREATE TABLE `contacto` (
  `id_contacto` int(11) NOT NULL AUTO_INCREMENT,
  `url_contacto` varchar(500) NOT NULL,
  PRIMARY KEY (`id_contacto`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8 COLLATE=utf8_spanish2_ci;

CREATE TABLE `formulario-contacto` (
  `id_formulario` int(11) NOT NULL AUTO_INCREMENT,
  `correo_formulario` varchar(150) NOT NULL,
  `nombre_formulario` varchar(150) NOT NULL,
  `telefono_formulario` bigint(13) NOT NULL,
  `mensaje_formulario` text NOT NULL,
  `fecha-formulario` timestamp NOT NULL DEFAULT current_timestamp() ON UPDATE current_timestamp(),
  PRIMARY KEY (`id_formulario`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8 COLLATE=utf8_spanish2_ci;

CREATE TABLE `usuario` (
  `id_usuario` int(11) NOT NULL AUTO_INCREMENT,
  `usuario` varchar(200) NOT NULL,
  `password` varchar(200) NOT NULL,
  PRIMARY KEY (`id_usuario`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8 COLLATE=utf8_spanish2_ci;
```

7.5 Consultas SQL utilizadas por el aplicativo

Archivo	Operación	Sentencia (resumen)
tema.php	Leer tema	`SELECT banner_inicio, paleta_banner FROM inicio ORDER BY id_inicio LIMIT 1`
index.php	Leer contenido	`SELECT * FROM inicio ORDER BY id_inicio LIMIT 1`
index-formulario.php	CRUD	`INSERT INTO inicio (…) VALUES (?,…); UPDATE inicio SET … WHERE id_inicio = ?; DELETE FROM inicio WHERE id_inicio = ?`
productos.php	Listar	`SELECT * FROM productos ORDER BY id_producto`
productos-formulario.php	CRUD	`INSERT / UPDATE / DELETE … productos … WHERE id_producto = ?`
contactos.php / -formulario	Leer / crear / editar	`SELECT * FROM contacto LIMIT 1; INSERT INTO contacto (url_contacto) VALUES (?); UPDATE contacto SET url_contacto = ? WHERE id_contacto = ?`
formulario-contacto.php	Registrar mensaje	`INSERT INTO `formulario-contacto` (correo…, nombre…, telefono…, mensaje…) VALUES (?,?,?,?)`
login.php	Autenticar	`SELECT id_usuario, usuario, password FROM usuario WHERE usuario = ? LIMIT 1`
imagenes-editor.php	Uso de imágenes	`SELECT COUNT(*) FROM `tabla` WHERE col1 = ? OR col2 = ? …`

Tabla 11. Consultas del aplicativo (todas las que reciben datos del usuario son preparadas).

7.6 Análisis de normalización

- **Primera forma normal:** los valores son atómicos, salvo `paleta_banner` (JSON) que se trata como un único valor de configuración.
- **Tabla inicio:** los grupos repetidos `acor1..5` y `colapsar1..3` violan la 1FN en sentido estricto (grupos de columnas). Es una decisión de simplicidad aceptable para un registro único; en una versión futura conviene una tabla `inicio_item(id, tipo, orden, titulo, texto)`.
- **Tabla productos:** las 3 columnas de imagen podrían pasar a `producto_imagen(id_producto FK, orden, ruta)` para permitir N imágenes.
- **Segunda y tercera forma normal:** se cumplen (llaves simples y sin dependencias transitivas).

7.7 Recomendaciones para la base de datos

N.º	Recomendación	Prioridad
BD1	Agregar la tabla `contacto` al archivo de respaldo del proyecto.	Alta
BD2	Cambiar `telefono_formulario` a `VARCHAR(20) NULL` (los teléfonos no son cantidades y el campo es opcional).	Alta
BD3	Crear un usuario de BD exclusivo con permisos SELECT, INSERT, UPDATE y DELETE sobre la base, en lugar de `root`.	Alta
BD4	Agregar índice único a `usuario.usuario`.	Media

N.º	Recomendación	Prioridad
BD5	Migrar a `utf8mb4 / utf8mb4_spanish_ci` para soportar emojis en mensajes.	Media
BD6	Quitar `ON UPDATE current_timestamp()` de `fecha-formulario` para conservar la fecha original si se edita el registro.	Media
BD7	Evitar guiones en nombres de tablas y columnas (`formulario_contacto`, `fecha_formulario`).	Baja

```
-- Ejemplo de usuario de base de datos con privilegios mínimos (BD3)
CREATE USER 'pizza_app'@'localhost' IDENTIFIED BY 'ContraseñaSegura-2026';
GRANT SELECT, INSERT, UPDATE, DELETE ON `tecnico-2026-pagina`.* TO 'pizza_app'@'localhost';
FLUSH PRIVILEGES;

-- Corrección del campo teléfono (BD2) y fecha (BD6)
ALTER TABLE `formulario-contacto`
  MODIFY `telefono_formulario` varchar(20) NULL,
  MODIFY `fecha-formulario` timestamp NOT NULL DEFAULT current_timestamp();
ALTER TABLE `usuario` ADD UNIQUE KEY `uq_usuario` (`usuario`);
```

7.8 Copias de seguridad

Desde consola (Shell de XAMPP):

```
# Respaldo completo
mysqldump -u root --routines --single-transaction tecnico-2026-pagina > respaldo_2026-10-18.
  sql
# Restauración
mysql -u root -e "CREATE DATABASE IF NOT EXISTS `tecnico-2026-pagina` CHARACTER SET utf8 COL
  LATE utf8_spanish2_ci"
mysql -u root tecnico-2026-pagina < respaldo_2026-10-18.sql
```

Respaldar también las carpetas `inicio/img-inicio` y `productos/img-productos`, porque la base de datos solo guarda las rutas. Frecuencia recomendada: semanal y antes de cada cambio.

8. Explicación de la codificación

8.1 Ciclo de una petición

Todas las páginas PHP siguen el mismo esquema: (1) cargar librerías con `require_once`; (2) `iniciarSesionSegura()` y `enviarCabecerasSinCache()`; (3) en los editores, comprobar `usuarioAutenticado()`; (4) abrir la conexión `mysqli`; (5) si la petición es POST, validar el token CSRF, procesar la acción y redirigir con 303; (6) si es GET, consultar los datos y (7) imprimir el HTML escapando cada valor con `htmlspecialchars`.

8.2 sesion.php – sesión segura y protección CSRF

```php
// Arranca la sesión con cookies httponly/samesite para mitigar robo de sesión (XSS/CSRF)
function iniciarSesionSegura(): void
{
    if (session_status() === PHP_SESSION_NONE) {
        session_set_cookie_params([
            "lifetime" => 0,
            "path" => "/",
            "domain" => "",
            "secure" => isset($_SERVER["HTTPS"]) && $_SERVER["HTTPS"] !== "off",
            "httponly" => true,
            "samesite" => "Lax",
        ]);
        session_start();
    }
}

function usuarioAutenticado(): bool
{
    return !empty($_SESSION["usuario_id"]);
}

// Token anti-CSRF asociado a la sesión del visitante
function generarTokenCsrf(): string
{
    if (empty($_SESSION["csrf_token"])) {
        $_SESSION["csrf_token"] = bin2hex(random_bytes(32));
    }
    return $_SESSION["csrf_token"];
}
```

Elemento	Descripción
`session_set_cookie_params`	Cookie de sesión sin expiración fija (dura mientras el navegador esté abierto), HttpOnly (inaccesible para JavaScript), SameSite=Lax y Secure cuando hay HTTPS.
`generarTokenCsrf()`	Crea un token aleatorio de 32 bytes (256 bits) con `random_bytes` y lo guarda en la sesión.
`csrfValido()`	Compara el token recibido con `hash_equals` (tiempo constante, evita ataques de temporización).
`enviarCabecerasSinCache()`	Envía `Cache-Control: no-store` para que el navegador no guarde copias de páginas con sesión.

8.3 login.php – autenticación

```php
// Bloqueo temporal tras varios intentos fallidos (mitiga fuerza bruta)
$_SESSION["intentos_login"] = $_SESSION["intentos_login"] ?? 0;
$_SESSION["bloqueo_login_hasta"] = $_SESSION["bloqueo_login_hasta"] ?? 0;

if (time() < (int) $_SESSION["bloqueo_login_hasta"]) {
    http_response_code(429);
    responderJson(false, "Demasiados intentos fallidos. Intente de nuevo en unos minutos.");
}

$usuario = trim((string) ($entrada["usuario"] ?? ""));
$password = (string) ($entrada["password"] ?? "");

if ($usuario === "" || $password === "" || mb_strlen($usuario) > 200 || mb_strlen($password) > 200) {
    responderJson(false, "Usuario y contraseña son obligatorios.");
}

$mysqli = new mysqli("localhost", "root", "", "tecnico-2026-pagina");
if ($mysqli->connect_error) {
    http_response_code(500);
    responderJson(false, "Error de conexión con el servidor.");
}

// Consulta preparada con parámetros ligados: evita inyección SQL
```

```php
$stmt = $mysqli->prepare("SELECT id_usuario, usuario, password FROM usuario WHERE usuario = ? LIMIT 1");
$stmt->bind_param("s", $usuario);
$stmt->execute();
$fila = $stmt->get_result()->fetch_assoc();
$stmt->close();
$mysqli->close();

// password_verify compara contra el hash almacenado (bcrypt), nunca en texto plano
if (!$fila || !password_verify($password, (string) $fila["password"])) {
    $_SESSION["intentos_login"]++;
    if ($_SESSION["intentos_login"] >= 5) {
        $_SESSION["bloqueo_login_hasta"] = time() + 300;
        $_SESSION["intentos_login"] = 0;
    }
    responderJson(false, "Usuario o contraseña incorrectos.");
}

$_SESSION["intentos_login"] = 0;
$_SESSION["bloqueo_login_hasta"] = 0;
session_regenerate_id(true); // evita fijación de sesión al cambiar de privilegio

$_SESSION["usuario_id"] = (int) $fila["id_usuario"];
$_SESSION["usuario_nombre"] = $fila["usuario"];
$_SESSION["login_time"] = time();
unset($_SESSION["csrf_token"]); // el token de login ya no es reutilizable

responderJson(true, "Inicio de sesión correcto.", "index-formulario.php");
```

Puntos clave: el servicio solo acepta POST (405 en otro caso); valida el token CSRF (403); aplica bloqueo de 300 s tras 5 fallos (429); limita la longitud de los campos a 200 caracteres; consulta con sentencia preparada; verifica con `password_verify`; regenera el identificador de sesión (`session_regenerate_id(true)`) para evitar fijación de sesión, e invalida el token de login usado.

8.4 logout.php – cierre de sesión

```php
// Página pública a la que se regresa según el editor desde el que se cerró la sesión (lista cerrada: evita redirecciones abiertas)
$paginasDestino = [
    "inicio" => "index.php",
    "productos" => "../productos/productos.php",
    "contacto" => "../contacto/contactos.php",
];
$destinoSolicitado = is_string($_POST["destino"] ?? null) ? $_POST["destino"] : "";
$paginaDestino = $paginasDestino[$destinoSolicitado] ?? "index.php";

// El cierre de sesión es una acción que cambia estado: solo se acepta por POST con token CSRF válido
if ($_SERVER["REQUEST_METHOD"] !== "POST" || !csrfValido($_POST["csrf_token"] ?? null)) {
    header("Location: " . $paginaDestino);
    exit;
}

$_SESSION = [];
if (ini_get("session.use_cookies")) {
    $parametrosCookie = session_get_cookie_params();
    setcookie(
        session_name(),
        "",
        time() - 42000,
        $parametrosCookie["path"],
        $parametrosCookie["domain"],
        $parametrosCookie["secure"],
        $parametrosCookie["httponly"]
    );
}
session_destroy();

// Pide al navegador borrar la caché del sitio para que no queden copias de los editores protegidos
header('Clear-Site-Data: "cache"');

header("Location: " . $paginaDestino);
exit;
```

8.5 imagenes-editor.php – carga segura de imágenes

```php
function guardarImagenSubida(?array $archivo, string $directorio, string $prefijo, ?string &$error): ?string
{
    if (!$archivo || $archivo["error"] === UPLOAD_ERR_NO_FILE) {
        return null;
    }
    if ($archivo["error"] !== UPLOAD_ERR_OK || $archivo["size"] <= 0 || $archivo["size"] > TAMANO_MAXIMO_IMAGEN) {
        $error = "error_imagen";
        return null;
    }

    $tipoMime = (new finfo(FILEINFO_MIME_TYPE))->file($archivo["tmp_name"]);
    $dimensiones = @getimagesize($archivo["tmp_name"]);
    if (!isset(TIPOS_IMAGEN_PERMITIDOS[$tipoMime]) || $dimensiones === false || $dimensiones[0] <= 0 || $dimensiones[1] <= 0) {
        $error = "error_imagen";
        return null;
    }

    $nombreArchivo = uniqid($prefijo, true) . "." . TIPOS_IMAGEN_PERMITIDOS[$tipoMime];
    if (!move_uploaded_file($archivo["tmp_name"], "$directorio/$nombreArchivo")) {
        $error = "error";
        return null;
    }
    return "./" . basename($directorio) . "/$nombreArchivo";
}
```

Elemento	Descripción
Validación de tamaño	Rechaza archivos vacíos o mayores de 5 MB (`TAMANO_MAXIMO_IMAGEN`).
Validación de contenido	`finfo` detecta el tipo MIME real a partir de los bytes del archivo y `getimagesize` confirma que es una imagen con dimensiones válidas: un archivo de texto renombrado como .jpg es rechazado (prueba P14).
Nombre seguro	La extensión se toma del tipo MIME detectado, nunca del nombre original; el nombre se genera con `uniqid(prefijo, true)`.
`descartarImagenesSubidas`	Si el guardado en BD falla, borra los archivos subidos en ese envío (consistencia BD–disco).
`eliminarImagenesReemplazadas`	Borra imágenes antiguas solo si ningún otro registro las usa y no están en la lista de imágenes protegidas; `basename` impide salir de la carpeta (path traversal).

8.6 Editores de contenido (patrón CRUD + PRG)

Los tres editores comparten la misma estructura. Fragmento del Editor de Productos:

```php
// Rechaza envíos del editor sin token CSRF válido (evita modificaciones desde otros sitios)
if ($_SERVER["REQUEST_METHOD"] === "POST" && !csrfValido($_POST["csrf_token"] ?? null)) {
    header("Location: productos-formulario.php?estado=error", true, 303);
    exit;
}

if ($_SERVER["REQUEST_METHOD"] === "POST") {
    $accion = $_POST["accion"] ?? "";
    $estado = "error";

    if ($accion === "eliminar") {
```

```php
        if ($accion === "crear") {
            $columnasSql = implode(", ", array_map(fn($c) => "`$c`", $columnasProductos));
            $marcadores = implode(", ", array_fill(0, count($columnasProductos), "?"));
            $stmt = $mysqli->prepare("INSERT INTO `productos` ($columnasSql) VALUES ($marcadores)");
            $tipos = str_repeat("s", count($valores));
            $stmt->bind_param($tipos, ...$valores);
            $estado = $stmt->execute() ? "creado" : "error";
            $stmt->close();
```

```
116         } else {
117             $setClause = implode(", ", array_map(fn($c) => "`$c` = ?", $columnasProductos));
118             $stmt = $mysqli->prepare("UPDATE `productos` SET $setClause WHERE id_producto = ?");
119             $tipos = str_repeat("s", count($valores)) . "i";
120             $valores[] = $id;
121             $stmt->bind_param($tipos, ...$valores);
122             $estado = $stmt->execute() ? "actualizado" : "error";
123             $stmt->close();
124         }
```

El formulario de cada modal se genera con una función (`renderModalInicio`, `renderModalProducto`, `renderModalContacto`) que recibe la acción (crear o editar) y la fila; así un mismo formulario sirve para ambas operaciones. Las imágenes actuales se leen de la base de datos y no de campos ocultos, para que el navegador no pueda alterarlas.

8.7 tema.php y tema.js – banner y paleta dinámica

`tema.php` lee el banner y la paleta del primer registro de `inicio`, valida que la ruta esté dentro de `img-inicio` y que cada color tenga formato `#rrggbb` (evita inyección de CSS), y los imprime como variables CSS `--pizza-*`. En el navegador, `tema.js` calcula la paleta:

1. Dibuja el banner en un `canvas` de 160 px de ancho y lee sus píxeles.
2. Construye un histograma de tonos (36 grupos de 10°) con los píxeles saturados (S > 0,45; 0,25 < L < 0,75).
3. Toma el tono dominante (promedio circular con sus vecinos) como "naranja", el más oscuro como "rojo" y el más claro como "amarillo".
4. Ajusta la luminosidad de cada color hasta cumplir la luminancia relativa requerida (fórmula de WCAG), garantizando contraste con el texto.
5. Si la imagen casi no tiene color, devuelve `null` y se usa la paleta por defecto.

```
67    function luminancia(hex) {
68      var canales = [1, 3, 5].map(function (i) {
69        var v = parseInt(hex.substr(i, 2), 16) / 255;
70        return v <= 0.03928 ? v / 12.92 : Math.pow((v + 0.055) / 1.055, 2.4);
71      });
72      return 0.2126 * canales[0] + 0.7152 * canales[1] + 0.0722 * canales[2];
73    }
```

8.8 formulario-contacto.php – registro y correo

```
34  if ($_SERVER["REQUEST_METHOD"] == "POST") {
35      $email = filter_var(trim($_POST["correo"] ?? ""), FILTER_VALIDATE_EMAIL);
36      $nombre = trim($_POST["nombre"] ?? "");
37      $telefono = trim($_POST["telefono"] ?? "");
38      $texto_area = trim($_POST["texto_area"] ?? "");
39
40      if ($email === false || $nombre === "" || $texto_area === "") {
41          http_response_code(422);
42          exit("Por favor, completa el nombre, un correo válido y el mensaje.");
43      }
44
45      $stmt = $mysqli->prepare("INSERT INTO `formulario-contacto` (correo_formulario, nombre_formulario,
     telefono_formulario, mensaje_formulario) VALUES (?, ?, ?, ?)");
46      if ($stmt === false) {
47          error_log("Error al preparar el registro del formulario: " . $mysqli->error);
48          http_response_code(500);
49          exit("No fue posible procesar el formulario.");
50      }
51
52      $stmt->bind_param('ssss', $email, $nombre, $telefono, $texto_area);
```

Las credenciales SMTP se leen de variables de entorno o del archivo `.env` (función `loadLocalEnv`), nunca del código. PHPMailer se conecta a `smtp.gmail.com:587` con STARTTLS y agrega `Reply-To` con el correo del visitante.

8.9 Páginas públicas

Las páginas públicas cargan el contenido con valores de respaldo (si la tabla está vacía o un campo viene vacío se usa un valor por defecto), normalizan la URL de YouTube al formato `/embed/` y limpian el número de WhatsApp dejando solo dígitos:

```
56  $resultadoInicio = $mysqli->query("SELECT * FROM `inicio` ORDER BY id_inicio ASC LIMIT 1");
57  if ($resultadoInicio && $resultadoInicio->num_rows > 0) {
58      $filaInicio = $resultadoInicio->fetch_assoc();
59      foreach ($datosInicio as $campo => $valorPorDefecto) {
60          $valor = trim((string) ($filaInicio[$campo] ?? ""));
61          $datosInicio[$campo] = $valor !== "" ? $valor : $valorPorDefecto;
62      }
63  }
64
65  $mysqli->close();
66
67  $datosInicio["url_video_inicio"] = normalizarUrlYoutubeEmbed($datosInicio["url_video_inicio"
    ]);
68  $whatsappInicio = preg_replace('/\D/', '', $datosInicio["numero_whatsapp"]);
```

8.10 Interfaz (HTML, CSS y JavaScript)

- **Bootstrap 5.3.8** (local) para rejilla responsive, barra de navegación, modales, carruseles, acordeón y colapsables; **Bootstrap Icons** desde CDN.
- **CSS por módulo** (`inicio.css`, `productos.css`, `contactos.css`) basado en las variables `--pizza-negro, --pizza-naranja, --pizza-rojo`… que redefine el tema.
- **Modal de login** con contador de 30 s (`setInterval`), envío con `fetch` y `location.replace` para no dejar páginas protegidas en el historial.
- **Vista previa de imágenes** en los editores con `URL.createObjectURL` y validación de tipo y tamaño antes de enviar.
- **Evento pageshow**: si el navegador muestra una página desde la caché (botón Atrás), la recarga para reflejar el estado real de la sesión.

9. Seguridad del aplicativo

9.1 Controles implementados frente a OWASP Top 10:2025

Riesgo OWASP 2025	Control en el aplicativo	Estado
A01 Control de acceso roto	`usuarioAutenticado()` en cada editor; redirección a la página pública; destinos de logout en lista cerrada.	Cumple
A02 Configuración de seguridad incorrecta	Cabeceras no-store. Faltan cabeceras CSP, X-Frame-Options y X-Content-Type-Options; BD con root sin contraseña; .zip con .env en la raíz web.	Parcial
A03 Fallas en la cadena de suministro de software	Dependencias versionadas (Composer, Bootstrap local). Íconos desde CDN sin SRI.	Parcial

Riesgo OWASP 2025	Control en el aplicativo	Estado
A04 Fallas criptográficas	bcrypt para contraseñas; token CSRF con `random_bytes`; cookie Secure con HTTPS. Sin HTTPS forzado en producción.	Parcial
A05 Inyección	Sentencias preparadas en todas las consultas con datos externos; salida escapada; validación de rutas y colores del tema.	Cumple
A06 Diseño inseguro	Bloqueo por intentos, PRG, validación del lado del servidor. El bloqueo se guarda en la sesión (se evita borrando la cookie).	Parcial
A07 Fallas de autenticación	Regeneración de sesión, mensajes genéricos, límite de 30 s del modal. Sin expiración por inactividad.	Parcial
A08 Fallas de integridad de software o datos	CSRF en editores, login y logout. El formulario público de contacto no tiene CSRF ni límite de envíos.	Parcial
A09 Fallas de registro y alertas	Solo `error_log` en el formulario de contacto; no hay registro de inicios de sesión.	Pendiente
A10 Manejo inadecuado de condiciones excepcionales	Mensajes controlados en la mayoría de flujos. Excepción no capturada con teléfono vacío (HTTP 500) y `die()` que muestra el error de conexión.	Parcial

Tabla 12. Matriz OWASP Top 10:2025.

9.2 Hallazgos y recomendaciones

ID	Hallazgo	Riesgo	Recomendación
H01	El archivo `contacto.zip` (≈ 103 MB) está dentro de la raíz web e incluye `contacto/.env` con la contraseña de aplicación de Gmail: cualquiera que conozca la URL puede descargarlo.	Crítico	Retirar el .zip de `htdocs` de inmediato y revocar/regenerar la contraseña de aplicación de Google.
H02	Credenciales de BD (`root` sin contraseña) repetidas en 9 archivos.	Alto	Centralizar en `config/conexion.php` con variables de entorno y usuario de privilegios mínimos (BD3).
H03	El formulario de contacto no tiene token CSRF, captcha ni límite de envíos.	Medio	Agregar token CSRF, campo trampa (honeypot) y límite por IP.
H04	El bloqueo de intentos de login se guarda en la sesión del atacante.	Medio	Registrar intentos por usuario/IP en una tabla de BD.
H05	Teléfono vacío o con espacios produce HTTP 500 (BIGINT NOT NULL y excepción no capturada).	Medio	Validar con `preg_replace('/\D/', '', $tel)`, cambiar la columna a VARCHAR(20) NULL y usar try/catch.
H06	`die("Error de conexión: " . $mysqli->connect_error)` muestra detalles internos.	Bajo	Registrar el error con `error_log` y mostrar un mensaje genérico.
H07	Sin cabeceras de seguridad HTTP.	Bajo	Agregar en Apache: CSP, `X-Content-Type-Options: nosniff`, `X-Frame-Options: SAMEORIGIN`, HSTS.
H08	Sesión sin expiración por inactividad (`login_time` se guarda pero no se usa).	Bajo	Cerrar la sesión tras 30 minutos de inactividad.

ID	Hallazgo	Riesgo	Recomendación
H09	La URL del mapa no se valida contra el dominio de Google Maps.	Bajo	Aceptar solo URLs que inicien con `https://www.google.com/maps/embed`.
H10	Páginas con `lang="en"` y imágenes con `alt="..."`.	Bajo (acce sibilidad)	Usar `lang="es"` y textos alternativos descriptivos (WCAG 2.2: 3.1.1 y 1.1.1).
H11	PHP 8.2 termina su soporte de seguridad el 31/12/2026.	Medio	Probar y migrar a PHP 8.4 o 8.5.
H12	El número de WhatsApp está fijo en `productos.php` y `contactos.php` y los enlaces de redes sociales apuntan a "#".	Bajo	Leer el número desde la tabla `inicio` en todas las páginas.

Tabla 13. Hallazgos de la revisión técnica.

> **IMPORTANTE**
> El hallazgo H01 debe atenderse antes de publicar el sitio en internet: la contraseña de aplicación de Gmail queda expuesta en el archivo comprimido.

9.3 Código sugerido

```
<?php
// config/conexion.php  (H02) — única conexión para todo el proyecto
declare(strict_types=1);
function conectarBD(): mysqli
{
    mysqli_report(MYSQLI_REPORT_ERROR | MYSQLI_REPORT_STRICT);
    try {
        $db = new mysqli(getenv("DB_HOST") ?: "localhost", getenv("DB_USER") ?: "pizza_app",
                         getenv("DB_PASS") ?: "", getenv("DB_NAME") ?: "tecnico-2026-pagina"
  );
        $db->set_charset("utf8mb4");
        return $db;
    } catch (mysqli_sql_exception $e) {
        error_log("BD: " . $e->getMessage());          // (H06) no se muestra al usuario
        http_response_code(503);
        exit("Servicio no disponible. Intente más tarde.");
    }
}

// formulario-contacto.php  (H05) — teléfono opcional y seguro
$telefono = preg_replace('/\D/', '', (string) ($_POST["telefono"] ?? ""));
$telefono = $telefono === "" ? null : substr($telefono, 0, 20);
```

10. Instalación, configuración y despliegue

10.1 Requisitos del servidor

Recurso	Mínimo	Recomendado
Sistema operativo	Windows 10/11, Linux o macOS	Linux (producción)
PHP	8.1 con mysqli, fileinfo, mbstring, openssl	8.4 o 8.5
Base de datos	MariaDB 10.4 / MySQL 8.0	MariaDB 10.11 LTS / 11.4 LTS
Servidor web	Apache 2.4	Apache 2.4 con HTTPS (Let's Encrypt)
Composer	2.x	2.x
Disco	300 MB	1 GB (imágenes)

10.2 Instalación en XAMPP (entorno local)

1. Instalar XAMPP y abrir su Panel de Control; iniciar **Apache** y **MySQL**.
2. Copiar la carpeta `pizza-julian` en `C:\xampp\htdocs\` (o en la ruta de htdocs configurada, p. ej. `D:\MATERIAL\xampp\htdocs\`).
3. Crear la base de datos importando el script DDL del numeral 7.4 o el respaldo `bd/tecnico-2026-pagina.sql` (agregando la tabla `contacto`).
4. Instalar la dependencia de correo: en `pizza-julian/contacto` ejecutar `composer install`.
5. Crear el archivo `contacto/.env` con `GMAIL_USERNAME` y `GMAIL_APP_PASSWORD` (contraseña de aplicación de Google).
6. Crear el primer administrador (numeral 10.4).
7. Abrir `http://localhost/pizza-julian/inicio/index.php`, iniciar sesión y crear el contenido inicial desde el Editor de Inicio.

10.3 Archivo .env

```
# contacto/.env  (no versionar: ya incluido en contacto/.gitignore)
GMAIL_USERNAME=cuenta.pizzeria@gmail.com
GMAIL_APP_PASSWORD=xxxx xxxx xxxx xxxx
```

10.4 Creación de administradores

```
php -r "echo password_hash('ClaveSegura2026*', PASSWORD_DEFAULT), PHP_EOL;"
-- copiar el resultado ($2y$10$...) y ejecutar en phpMyAdmin:
INSERT INTO usuario (usuario, password) VALUES ('admin', '$2y$10$...');
```

10.5 Despliegue en producción (lista de verificación)

Hecho	Actividad
[ ]	Retirar de la raíz web `contacto.zip`, `bd/`, `.vscode/` y `.refact/` (o denegar su acceso en Apache).
[ ]	Configurar HTTPS y redirigir HTTP → HTTPS.
[ ]	Usuario de BD con privilegios mínimos y contraseña robusta.
[ ]	En `php.ini`: `display_errors=Off`, `log_errors=On`, `expose_php=Off`, `upload_max_filesize=6M`, `post_max_size=25M`.
[ ]	Denegar la ejecución de PHP en `img-inicio/` e `img-productos/`.
[ ]	Restringir phpMyAdmin a localhost o VPN.
[ ]	Agregar cabeceras de seguridad (H07) y política de tratamiento de datos (Ley 1581 de 2012).
[ ]	Programar copias de seguridad de BD e imágenes.

```
# .htaccess dentro de img-inicio/ e img-productos/
<FilesMatch "\.(php|phtml|phar)$">
    Require all denied
</FilesMatch>
Options -Indexes
```

11. Plan y resultados de pruebas

11.1 Estrategia

Se aplicaron pruebas funcionales de caja negra y pruebas de seguridad automatizadas con `curl` sobre una copia del aplicativo (PHP 8.3.6, MariaDB 10.11.14), siguiendo la estructura de casos de prueba de ISO/IEC/IEEE 29119-3. Además, se recorrieron manualmente todas las pantallas para elaborar el Manual de Usuario.

ID	Caso de prueba	Resultado obtenido	Estado
P01	Carga de la página de Inicio	HTTP 200	**Aprobada**
P02	Carga de la página de Productos	HTTP 200	**Aprobada**
P03	Carga de la página de Contacto	HTTP 200	**Aprobada**
P04	Acceso al editor sin sesión	302 http://127.0.0.1:8080/pizza-julian/inicio/index.php	**Aprobada**
P05	Acceso al editor de productos sin sesión	302 http://127.0.0.1:8080/pizza-julian/productos/productos.php	**Aprobada**
P06	Login sin token CSRF	{"ok":false,"mensaje":"La sesión expiró, recargue la página e intente nuevamente.","redirect":null} HTTP 403	**Aprobada**
P07	Inyección SQL en el login	{"ok":false,"mensaje":"Usuario o contraseña incorrectos.","redirect":null}	**Aprobada**
P08	Quinto intento fallido de login	{"ok":false,"mensaje":"Usuario o contraseña incorrectos.","redirect":null}	**Aprobada**

ID	Caso de prueba	Resultado obtenido	Estado
P09	Sexto intento (aun con clave correcta) tras 5 fallos	{"ok":false,"mensaje":"Demasiados intentos fallidos. Intente de nuevo en unos minutos.","redirect":null} HTTP 429	**Aprobada**
P10	Login con campos vacíos	{"ok":false,"mensaje":"Usuario y contraseña son obligatorios.","redirect":null}	**Aprobada**
P11	Login con credenciales válidas	{"ok":true,"mensaje":"Inicio de sesión correcto.","redirect":"index-formulario.php"}	**Aprobada**
P12	Acceso al editor con sesión iniciada	HTTP 200	**Aprobada**
P13	Envío al editor sin token CSRF	303 http://127.0.0.1:8080/pizza-julian/productos/productos-formulario.php?estado=error	**Aprobada**
P14	Subir archivo de texto renombrado como .jpg	303 http://127.0.0.1:8080/pizza-julian/productos/productos-formulario.php?estado=error_imagen	**Aprobada**
P15	Crear producto sin imágenes	303 http://127.0.0.1:8080/pizza-julian/productos/productos-formulario.php?estado=imagen_requerida	**Aprobada**
P16	Crear producto con 3 imágenes válidas	303 http://127.0.0.1:8080/pizza-julian/productos/productos-formulario.php?estado=creado	**Aprobada**
P17	Título con código <script> (XSS) se muestra escapado	4 coincidencias escapadas	**Aprobada**
P18	Eliminar el producto de prueba	303 http://127.0.0.1:8080/pizza-julian/productos/productos-formulario.php?estado=eliminado	**Aprobada**
P19	Formulario de contacto con correo inválido	Por favor, completa el nombre, un correo válido y el mensaje. HTTP 422	**Aprobada**
P19b	Mensaje válido sin cuenta SMTP configurada	La información se guardó, pero el correo no está configurado. HTTP 500 (registros 4 -> 5)	**Aprobada**
P20	Servicio tema-json.php	{"ok":true,"banner":"../inicio/img-inicio/inicio_6aaac2144cb9c1.12612393.png","paleta":{"negro":"#0f090a","negro-suave":	**Aprobada**
P21	Cerrar sesión por GET (no permitido) mantiene la sesión	logout GET 302, editor 200	**Aprobada**
P22	Cerrar sesión por POST con token y reintentar editor	302 http://127.0.0.1:8080/pizza-julian/inicio/index.php	**Aprobada**
P23	Cookie de sesión HttpOnly y SameSite	Set-Cookie: PHPSESSID=sd7ajm3hq3tvpn7vb3q8m07a3a; path=/; HttpOnly; SameSite=Lax	**Aprobada**
P24	Formulario de contacto con el teléfono vacío (campo opcional en la interfaz)	HTTP 500: excepción mysqli_sql_exception no capturada (telefono_formulario es BIGINT NOT NULL)	**Fallida**
P25	Formulario de contacto con teléfono escrito con espacios ("300 123 4567")	HTTP 500: el valor no es numérico para BIGINT en modo estricto	**Fallida**

Tabla 14. Resultados de las pruebas: 24 de 26 aprobadas.

Los casos P24 y P25 evidencian el defecto H05: el campo Teléfono es opcional en la interfaz, pero la columna `telefono_formulario` es BIGINT NOT NULL y PHP 8.1+ lanza `mysqli_sql_exception` sin capturar. La corrección se describe en el numeral 9.3 y en la recomendación BD2.

> **NOTA**
> El caso P19b se ejecutó sin cuenta SMTP: el mensaje se guardó en la base de datos y el sistema informó que el correo no estaba configurado, que es el comportamiento esperado.

11.2 Pruebas de compatibilidad

Escenario	Resultado
Navegador Chromium, escritorio 1366 × 768	Correcto (capturas del Manual de Usuario).
Celular 390 × 844 (menú hamburguesa)	Correcto.
PHP 8.3 / MariaDB 10.11 (versiones superiores a las del proyecto)	Correcto, sin cambios de código.

12. Mantenimiento

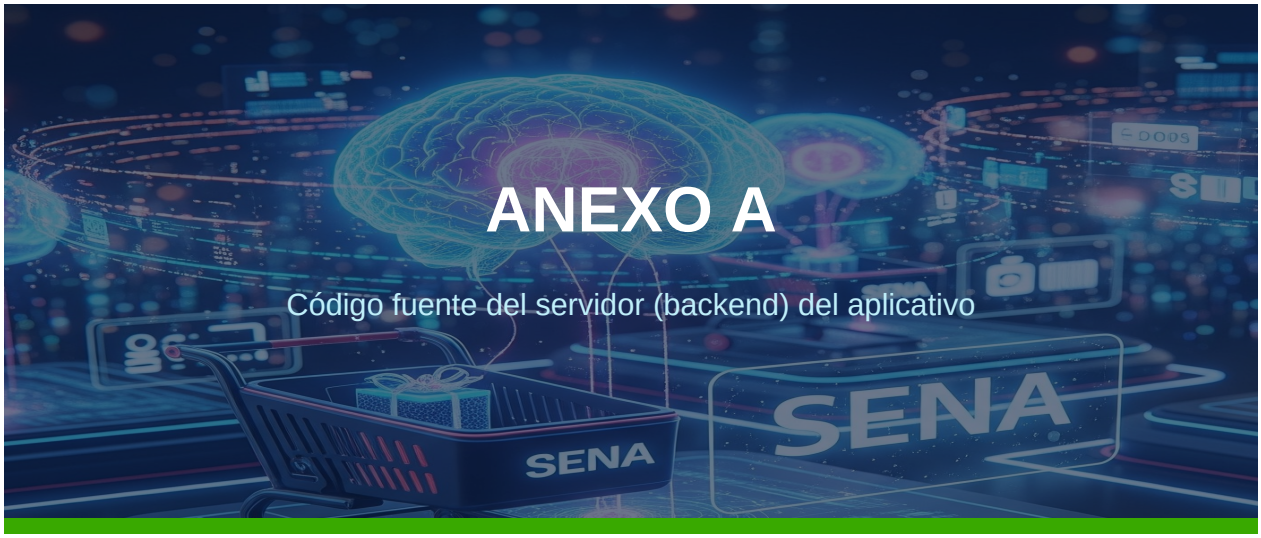
Tipo (ISO/IEC 14764)	Actividad	Frecuencia
Preventivo	Copia de seguridad de BD e imágenes; revisión de espacio en disco.	Semanal
Preventivo	Actualizar XAMPP/PHP, Composer (`composer update`) y Bootstrap.	Trimestral
Correctivo	Atender hallazgos H01–H12 según prioridad.	Inmediato / planificado
Adaptativo	Migración a PHP 8.4+ antes del 31/12/2026.	Una vez
Perfectivo	Carrito de compras, pedidos, pagos, gestión de usuarios y recomendaciones con IA.	Según hoja de ruta

12.1 Control de versiones

Se recomienda gestionar el proyecto con Git y un repositorio remoto privado, con ramas `main` (producción) y `desarrollo`, mensajes de commit descriptivos y un `.gitignore` que excluya `.env`, `vendor/`, archivos `*.zip` y las imágenes subidas por usuarios.

12.2 Hoja de ruta (visión a futuro SENA)

- Versión 1.1: corrección de hallazgos, archivo de configuración único y lectura de mensajes en un editor.
- Versión 2.0: catálogo con precios, carrito de compras y gestión de pedidos.
- Versión 3.0: pagos en línea, cuentas de clientes y recomendaciones de productos con inteligencia artificial.


ANEXO A
Código fuente del servidor (backend) del aplicativo
SENA
SENA

Anexo A. Código fuente

Se incluye el código PHP del servidor y el módulo JavaScript del tema. Por extensión se omiten el HTML de las vistas, las hojas de estilo y las librerías de terceros, que se encuentran en la carpeta del proyecto.

A. inicio/sesion.php

```php
<?php
declare(strict_types=1);

// Arranca la sesión con cookies httponly/samesite para mitigar robo de sesión (XSS/CSRF)
function iniciarSesionSegura(): void
{
    if (session_status() === PHP_SESSION_NONE) {
        session_set_cookie_params([
            "lifetime" => 0,
            "path" => "/",
            "domain" => "",
            "secure" => isset($_SERVER["HTTPS"]) && $_SERVER["HTTPS"] !== "off",
            "httponly" => true,
            "samesite" => "Lax",
        ]);
        session_start();
    }
}

function usuarioAutenticado(): bool
{
    return !empty($_SESSION["usuario_id"]);
}

// Token anti-CSRF asociado a la sesión del visitante
function generarTokenCsrf(): string
{
    if (empty($_SESSION["csrf_token"])) {
        $_SESSION["csrf_token"] = bin2hex(random_bytes(32));
    }
    return $_SESSION["csrf_token"];
}

function csrfValido(?string $token): bool
{
    return is_string($token) && $token !== "" && !empty($_SESSION["csrf_token"]) && hash_equ
als($_SESSION["csrf_token"], $token);
}

// Encabezados para impedir que el navegador guarde en caché páginas con datos de sesión
function enviarCabecerasSinCache(): void
{
    header("Cache-Control: no-store, no-cache, must-revalidate, max-age=0");
    header("Pragma: no-cache");
    header("Expires: 0");
}
```

A. inicio/login.php

```php
<?php
declare(strict_types=1);

require_once __DIR__ . "/sesion.php";
iniciarSesionSegura();
enviarCabecerasSinCache();

header("Content-Type: application/json; charset=UTF-8");

function responderJson(bool $ok, string $mensaje, ?string $redireccion = null): never
{
    echo json_encode(["ok" => $ok, "mensaje" => $mensaje, "redirect" => $redireccion], JSON_UNESCAPED_UNICODE);
    exit;
}

if ($_SERVER["REQUEST_METHOD"] !== "POST") {
    http_response_code(405);
    responderJson(false, "Método no permitido.");
}

$entrada = json_decode((string) file_get_contents("php://input"), true);
if (!is_array($entrada)) {
    $entrada = $_POST;
}

// Protección CSRF: el token debe coincidir con el generado para esta sesión
if (!csrfValido($entrada["csrf_token"] ?? null)) {
    http_response_code(403);
    responderJson(false, "La sesión expiró, recargue la página e intente nuevamente.");
}

// Bloqueo temporal tras varios intentos fallidos (mitiga fuerza bruta)
$_SESSION["intentos_login"] = $_SESSION["intentos_login"] ?? 0;
$_SESSION["bloqueo_login_hasta"] = $_SESSION["bloqueo_login_hasta"] ?? 0;

if (time() < (int) $_SESSION["bloqueo_login_hasta"]) {
    http_response_code(429);
    responderJson(false, "Demasiados intentos fallidos. Intente de nuevo en unos minutos.");
}

$usuario = trim((string) ($entrada["usuario"] ?? ""));
$password = (string) ($entrada["password"] ?? "");

if ($usuario === "" || $password === "" || mb_strlen($usuario) > 200 || mb_strlen($password) > 200) {
    responderJson(false, "Usuario y contraseña son obligatorios.");
}

$mysqli = new mysqli("localhost", "root", "", "tecnico-2026-pagina");
if ($mysqli->connect_error) {
    http_response_code(500);
    responderJson(false, "Error de conexión con el servidor.");
}

// Consulta preparada con parámetros ligados: evita inyección SQL
$stmt = $mysqli->prepare("SELECT id_usuario, usuario, password FROM usuario WHERE usuario = ? LIMIT 1");
$stmt->bind_param("s", $usuario);
$stmt->execute();
$fila = $stmt->get_result()->fetch_assoc();
$stmt->close();
$mysqli->close();

// password_verify compara contra el hash almacenado (bcrypt), nunca en texto plano
if (!$fila || !password_verify($password, (string) $fila["password"])) {
    $_SESSION["intentos_login"]++;
    if ($_SESSION["intentos_login"] >= 5) {
```

```
66          $_SESSION["bloqueo_login_hasta"] = time() + 300;
67          $_SESSION["intentos_login"] = 0;
68      }
69      responderJson(false, "Usuario o contraseña incorrectos.");
70  }
71
72  $_SESSION["intentos_login"] = 0;
73  $_SESSION["bloqueo_login_hasta"] = 0;
74  session_regenerate_id(true); // evita fijación de sesión al cambiar de privilegio
75
76  $_SESSION["usuario_id"] = (int) $fila["id_usuario"];
77  $_SESSION["usuario_nombre"] = $fila["usuario"];
78  $_SESSION["login_time"] = time();
79  unset($_SESSION["csrf_token"]); // el token de login ya no es reutilizable
80
81  responderJson(true, "Inicio de sesión correcto.", "index-formulario.php");
```

A. inicio/logout.php

```
 1  <?php
 2  declare(strict_types=1);
 3
 4  require_once __DIR__ . "/sesion.php";
 5  iniciarSesionSegura();
 6  enviarCabecerasSinCache();
 7
 8  // Página pública a la que se regresa según el editor desde el que se cerró la sesión (lista
     cerrada: evita redirecciones abiertas)
 9  $paginasDestino = [
10      "inicio" => "index.php",
11      "productos" => "../productos/productos.php",
12      "contacto" => "../contacto/contactos.php",
13  ];
14  $destinoSolicitado = is_string($_POST["destino"] ?? null) ? $_POST["destino"] : "";
15  $paginaDestino = $paginasDestino[$destinoSolicitado] ?? "index.php";
16
17  // El cierre de sesión es una acción que cambia estado: solo se acepta por POST con token CS
    RF válido
18  if ($_SERVER["REQUEST_METHOD"] !== "POST" || !csrfValido($_POST["csrf_token"] ?? null)) {
19      header("Location: " . $paginaDestino);
20      exit;
21  }
22
23  $_SESSION = [];
24  if (ini_get("session.use_cookies")) {
25      $parametrosCookie = session_get_cookie_params();
26      setcookie(
27          session_name(),
28          "",
29          time() - 42000,
30          $parametrosCookie["path"],
31          $parametrosCookie["domain"],
32          $parametrosCookie["secure"],
33          $parametrosCookie["httponly"]
34      );
35  }
36  session_destroy();
37
38  // Pide al navegador borrar la caché del sitio para que no queden copias de los editores pro
    tegidos
39  header('Clear-Site-Data: "cache"');
40
41  header("Location: " . $paginaDestino);
42  exit;
```

A. inicio/tema.php

```php
<?php
declare(strict_types=1);

// Tema visual compartido por todas las páginas (inicio, productos, contacto y sus editores).
// El banner y la paleta de colores salen del primer registro de la tabla `inicio`,
// así al cambiar el banner en el editor de Inicio todas las páginas se actualizan juntas.

const PALETA_POR_DEFECTO = [
    "negro" => "#0f090a",
    "negro-suave" => "#1a1113",
    "naranja" => "#ff8b1a",
    "amarillo" => "#ffc21a",
    "rojo" => "#d90a0a",
    "rojo-profundo" => "#8f0909",
    "rojo-vivo" => "#ff2e2e",
    "blanco" => "#f7f5f3",
    "gris" => "#e7e2de",
];
const BANNER_POR_DEFECTO = "./img-inicio/banner.png";

// Devuelve la paleta solo si trae todos los colores en formato #rrggbb; si no, null
function normalizarPaleta(?string $json): ?array
{
    $datos = json_decode((string) $json, true);
    if (!is_array($datos)) {
        return null;
    }
    $paleta = [];
    foreach (array_keys(PALETA_POR_DEFECTO) as $clave) {
        $color = strtolower(trim((string) ($datos[$clave] ?? "")));
        if (!preg_match('/^#[0-9a-f]{6}$/', $color)) {
            return null;
        }
        $paleta[$clave] = $color;
    }
    return $paleta;
}

function obtenerTemaSitio(mysqli $mysqli): array
{
    $banner = BANNER_POR_DEFECTO;
    $paleta = PALETA_POR_DEFECTO;

    $resultado = $mysqli->query("SELECT banner_inicio, paleta_banner FROM `inicio` ORDER BY id_inicio ASC LIMIT 1");
    if ($resultado && ($fila = $resultado->fetch_assoc())) {
        $valor = trim((string) $fila["banner_inicio"]);
        // solo rutas dentro de img-inicio (evita inyectar CSS en url())
        if (preg_match('~^\./img-inicio/[A-Za-z0-9._-]+$~', $valor)) {
            $banner = $valor;
        }
        $paleta = normalizarPaleta($fila["paleta_banner"]) ?? PALETA_POR_DEFECTO;
    }

    // Todas las páginas están un nivel dentro del proyecto, por eso la ruta sale desde ../inicio/
    $rutaBanner = "../inicio/" . substr($banner, 2);
    return [
        "banner" => $rutaBanner,
        "paleta" => $paleta,
        "version" => substr(md5($rutaBanner . json_encode($paleta)), 0, 12),
    ];
}

// Se imprime dentro de <head>: paleta del banner en variables CSS + script que sincroniza el tema al instante
function imprimirTemaSitio(array $tema): void
```

```
{
    $variables = "";
    foreach ($tema["paleta"] as $clave => $color) {
        $variables .= "--pizza-$clave: $color; ";
    }
    $variables .= "--banner-url: url(\"{$tema["banner"]}\");";
    ?>
    <link rel="stylesheet" href="../inicio/tema.css">
    <style id="tema-sitio" data-version="<?= htmlspecialchars($tema["version"], ENT_QUOTES) ?>">:root { <?= $variables ?> }</style>
    <script src="../inicio/tema.js" defer></script>
    <?php
}
```

A. inicio/tema-json.php

```
<?php
declare(strict_types=1);

// Devuelve el tema actual (banner + paleta) para que las páginas abiertas se actualicen sin recargar
require_once __DIR__ . "/tema.php";

header("Content-Type: application/json; charset=utf-8");
header("Cache-Control: no-store, no-cache, must-revalidate, max-age=0");

$mysqli = new mysqli("localhost", "root", "", "tecnico-2026-pagina");
if ($mysqli->connect_error) {
    http_response_code(500);
    echo json_encode(["ok" => false]);
    exit;
}
$tema = obtenerTemaSitio($mysqli);
$mysqli->close();

echo json_encode(["ok" => true] + $tema, JSON_UNESCAPED_SLASHES);
```

A. inicio/imagenes-editor.php

```
<?php
declare(strict_types=1);

// Manejo de imágenes compartido por los editores de contenido (index-formulario.php y productos-formulario.php)

// Tipos de imagen aceptados (se valida el contenido real del archivo, no solo la extensión)
const TIPOS_IMAGEN_PERMITIDOS = [
    "image/jpeg" => "jpg",
    "image/png" => "png",
    "image/gif" => "gif",
    "image/webp" => "webp",
];
const TAMANO_MAXIMO_IMAGEN = 5 * 1024 * 1024; // 5 MB por imagen

// Guarda una imagen subida y devuelve su ruta relativa (./carpeta/archivo); null si no se envió archivo.
// Si el archivo no es válido deja el código de estado en $error.
function guardarImagenSubida(?array $archivo, string $directorio, string $prefijo, ?string &$error): ?string
{
    if (!$archivo || $archivo["error"] === UPLOAD_ERR_NO_FILE) {
        return null;
    }
    if ($archivo["error"] !== UPLOAD_ERR_OK || $archivo["size"] <= 0 || $archivo["size"] > TAMANO_MAXIMO_IMAGEN) {
        $error = "error_imagen";
        return null;
```

```
25      }
26
27      $tipoMime = (new finfo(FILEINFO_MIME_TYPE))->file($archivo["tmp_name"]);
28      $dimensiones = @getimagesize($archivo["tmp_name"]);
29      if (!isset(TIPOS_IMAGEN_PERMITIDOS[$tipoMime]) || $dimensiones === false || $dimensiones
    [0] <= 0 || $dimensiones[1] <= 0) {
30          $error = "error_imagen";
31          return null;
32      }
33
34      $nombreArchivo = uniqid($prefijo, true) . "." . TIPOS_IMAGEN_PERMITIDOS[$tipoMime];
35      if (!move_uploaded_file($archivo["tmp_name"], "$directorio/$nombreArchivo")) {
36          $error = "error";
37          return null;
38      }
39      return "./" . basename($directorio) . "/$nombreArchivo";
40  }
41
42  // Descarta del disco las imágenes subidas en un envío que no llegó a guardarse en la BD
43  function descartarImagenesSubidas(array $rutas, string $directorio): void
44  {
45      foreach ($rutas as $ruta) {
46          $archivo = "$directorio/" . basename((string) $ruta);
47          if (is_file($archivo)) {
48              unlink($archivo);
49          }
50      }
51  }
52
53  // Borra del almacenamiento las imágenes antiguas que fueron reemplazadas o cuyo registro se
     eliminó.
54  // No borra un archivo si otro registro de la tabla todavía lo usa ni si el sitio lo usa fij
    o ($protegidas).
55  function eliminarImagenesReemplazadas(mysqli $mysqli, string $tabla, array $columnasImagen,
    array $rutas, string $directorio, array $protegidas = []): void
56  {
57      $condiciones = implode(" OR ", array_map(fn($c) => "`$c` = ?", $columnasImagen));
58      $carpeta = basename($directorio);
59
60      foreach (array_unique(array_filter(array_map("strval", $rutas))) as $ruta) {
61          $nombreArchivo = basename($ruta);
62          // solo archivos de la carpeta de imágenes del editor (basename impide salir de ella
    )
63          if ($nombreArchivo === "" || $nombreArchivo[0] === "." || in_array($nombreArchivo, $
    protegidas, true)) {
64              continue;
65          }
66
67          $rutaNormalizada = "./$carpeta/$nombreArchivo";
68          $parametros = array_fill(0, count($columnasImagen), $rutaNormalizada);
69          $stmt = $mysqli->prepare("SELECT COUNT(*) FROM `$tabla` WHERE $condiciones");
70          $stmt->bind_param(str_repeat("s", count($parametros)), ...$parametros);
71          $stmt->execute();
72          $stmt->bind_result($usos);
73          $stmt->fetch();
74          $stmt->close();
75
76          $archivo = "$directorio/$nombreArchivo";
77          if ($usos === 0 && is_file($archivo)) {
78              unlink($archivo);
79          }
80      }
81  }
```

A. contacto/formulario-contacto.php

```php
<?php

use PHPMailer\PHPMailer\Exception;
use PHPMailer\PHPMailer\PHPMailer;

require_once __DIR__ . "/vendor/autoload.php";

function loadLocalEnv(string $path): array
{
    if (!is_readable($path)) {
        return [];
    }

    $values = [];
    foreach (file($path, FILE_IGNORE_NEW_LINES | FILE_SKIP_EMPTY_LINES) as $line) {
        $line = trim($line);
        if ($line === '' || str_starts_with($line, '#') || !str_contains($line, '=')) {
            continue;
        }

        [$key, $value] = explode('=', $line, 2);
        $values[trim($key)] = trim($value, " \t\n\r\0\x0B\"");
    }

    return $values;
}

$mysqli = new mysqli("localhost", "root", "", "tecnico-2026-pagina");

if ($mysqli->connect_error) {
    die("Error de conexión: " . $mysqli->connect_error);
}

if ($_SERVER["REQUEST_METHOD"] == "POST") {
    $email = filter_var(trim($_POST["correo"] ?? ""), FILTER_VALIDATE_EMAIL);
    $nombre = trim($_POST["nombre"] ?? "");
    $telefono = trim($_POST["telefono"] ?? "");
    $texto_area = trim($_POST["texto_area"] ?? "");

    if ($email === false || $nombre === "" || $texto_area === "") {
        http_response_code(422);
        exit("Por favor, completa el nombre, un correo válido y el mensaje.");
    }

    $stmt = $mysqli->prepare("INSERT INTO `formulario-contacto` (correo_formulario, nombre_formulario, telefono_formulario, mensaje_formulario) VALUES (?, ?, ?, ?)");
    if ($stmt === false) {
        error_log("Error al preparar el registro del formulario: " . $mysqli->error);
        http_response_code(500);
        exit("No fue posible procesar el formulario.");
    }

    $stmt->bind_param('ssss', $email, $nombre, $telefono, $texto_area);
    if (!$stmt->execute()) {
        error_log("Error al guardar el formulario: " . $stmt->error);
        $stmt->close();
        $mysqli->close();
        http_response_code(500);
        exit("No fue posible guardar la información del formulario.");
    }

    $stmt->close();
    $mysqli->close();

    $env = loadLocalEnv(__DIR__ . "/.env");
    $smtpUsername = getenv("GMAIL_USERNAME") ?: ($env["GMAIL_USERNAME"] ?? "delfin.alber@gmail.com");
    $smtpPassword = getenv("GMAIL_APP_PASSWORD") ?: ($env["GMAIL_APP_PASSWORD"] ?? "");
```

```
67
68      if ($smtpPassword === "") {
69          error_log("No está configurada GMAIL_APP_PASSWORD para el formulario de contacto.");
70          http_response_code(500);
71          exit("La información se guardó, pero el correo no está configurado.");
72      }
73
74      try {
75          $mail = new PHPMailer(true);
76          $mail->isSMTP();
77          $mail->Host = "smtp.gmail.com";
78          $mail->SMTPAuth = true;
79          $mail->Username = $smtpUsername;
80          $mail->Password = $smtpPassword;
81          $mail->SMTPSecure = PHPMailer::ENCRYPTION_STARTTLS;
82          $mail->Port = 587;
83          $mail->CharSet = "UTF-8";
84
85          $mail->setFrom($smtpUsername, "Formulario PIZZERIA-JULIAN");
86          $mail->addAddress("delfin.alber@gmail.com");
87          $mail->addReplyTo($email, $nombre);
88          $mail->isHTML(false);
89          $mail->Subject = "Nuevo mensaje del formulario de contacto";
90          $mail->Body = "Nombre: {$nombre}\nCorreo: {$email}\nTeléfono: {$telefono}\n\nMensaje
    :\n{$texto_area}";
91          $mail->send();
92      } catch (Exception $exception) {
93          error_log("Error SMTP del formulario de contacto: " . $exception->getMessage());
94          http_response_code(502);
95          exit("La información se guardó, pero no se pudo enviar el correo.");
96      }
97
98      header("Cache-Control: no-store, no-cache, must-revalidate");
99      header("Location: contactos.php?envio=ok", true, 303);
100     exit;
101 }
```

A. inicio/index-formulario.php (lógica del servidor, líneas 1–184)

```
1  <?php
2  declare(strict_types=1);
3
4  require_once __DIR__ . "/sesion.php";
5  require_once __DIR__ . "/tema.php";
6  require_once __DIR__ . "/imagenes-editor.php";
7  iniciarSesionSegura();
8  enviarCabecerasSinCache();
9
10 // Solo usuarios autenticados (tabla `usuario`) pueden ver o modificar este editor
11 if (!usuarioAutenticado()) {
12     header("Location: index.php");
13     exit;
14 }
15
16 $tokenCsrfLogout = generarTokenCsrf();
17
18 $mysqli = new mysqli("localhost", "root", "", "tecnico-2026-pagina");
19 if ($mysqli->connect_error) {
20     die("Error de conexión: " . $mysqli->connect_error);
21 }
22 // Banner y paleta de colores compartidos por todas las páginas
23 $temaSitio = obtenerTemaSitio($mysqli);
24
25 // Convierte enlaces de YouTube (watch, youtu.be, shorts) al formato /embed/ requerido por e
   l iframe
26 function normalizarUrlYoutubeEmbed(string $url): string
27 {
28     $url = trim($url);
29     if ($url === "") {
```

```
30          return $url;
31      }
32      if (preg_match('~(?:youtu\.be/|youtube\.com/(?:embed/|watch\?v=|shorts/))([A-Za-z0-9_-]{
    6,})~i', $url, $coincidencia)) {
33          return "https://www.youtube.com/embed/" . $coincidencia[1];
34      }
35      return $url;
36  }
37
38  // Columnas de la tabla `inicio` que alimentan las variables de index.php
39  $columnasInicio = [
40      "banner_inicio", "carru-1", "carru-2", "carru-3", "url_video_inicio",
41      "acor1_titulo_inicio", "acor1_texto_inicio",
42      "acor2_titulo_inicio", "acor2_texto_inicio",
43      "acor3_titulo_inicio", "acor3_texto_inicio",
44      "acor4_titulo_inicio", "acor4_texto_inicio",
45      "acor5_titulo_inicio", "acor5_texto_inicio",
46      "colapsar1_titulo_inicio", "colapsar1_texto_inicio",
47      "colapsar2_titulo_inicio", "colapsar2_texto_inicio",
48      "colapsar3_titulo_inicio", "colapsar3_texto_inicio",
49      "numero_whatsapp", "paleta_banner",
50  ];
51  $camposImagen = ["banner_inicio", "carru-1", "carru-2", "carru-3"];
52  $directorioImagenes = __DIR__ . "/img-inicio";
53  // Imágenes que el sitio usa de forma fija (respaldo de index.php y fondos en inicio.css): n
    unca se borran
54  $imagenesProtegidas = ["banner.png", "footer.png", "1.jpeg", "2.jpeg", "3.jpeg"];
55
56  function obtenerFilaInicio(mysqli $mysqli, int $id): ?array
57  {
58      $stmt = $mysqli->prepare("SELECT * FROM `inicio` WHERE id_inicio = ?");
59      $stmt->bind_param("i", $id);
60      $stmt->execute();
61      $fila = $stmt->get_result()->fetch_assoc();
62      $stmt->close();
63      return $fila ?: null;
64  }
65
66  // Tras procesar el POST se redirige (patrón PRG) a index-formulario.php sin caché ni reenví
    o del formulario
67  // Rechaza envíos del editor sin token CSRF válido (evita modificaciones desde otros sitios)
68  if ($_SERVER["REQUEST_METHOD"] === "POST" && !csrfValido($_POST["csrf_token"] ?? null)) {
69      header("Location: index-formulario.php?estado=error", true, 303);
70      exit;
71  }
72
73  if ($_SERVER["REQUEST_METHOD"] === "POST") {
74      $accion = $_POST["accion"] ?? "";
75      $estado = "error";
76
77      if ($accion === "eliminar") {
78          $id = (int) ($_POST["id_inicio"] ?? 0);
79          $filaActual = $id > 0 ? obtenerFilaInicio($mysqli, $id) : null;
80          if ($filaActual) {
81              $stmt = $mysqli->prepare("DELETE FROM `inicio` WHERE id_inicio = ?");
82              $stmt->bind_param("i", $id);
83              $estado = $stmt->execute() ? "eliminado" : "error";
84              $stmt->close();
85              if ($estado === "eliminado") {
86                  eliminarImagenesReemplazadas($mysqli, "inicio", $camposImagen, array_map(fn(
    $c) => $filaActual[$c], $camposImagen), $directorioImagenes, $imagenesProtegidas);
87              }
88          }
89      } elseif ($accion === "crear" || $accion === "editar") {
90          $id = (int) ($_POST["id_inicio"] ?? 0);
91          // Las imágenes actuales se leen de la BD (no de campos ocultos que el navegador pod
    ría alterar)
92          $filaActual = $accion === "editar" ? obtenerFilaInicio($mysqli, $id) : [];
93          $valoresImagen = [];
94          $imagenesNuevas = [];
```

```
95          $errorImagen = $filaActual === null ? "error" : null;
96
97          if ($errorImagen === null) {
98              foreach ($camposImagen as $campo) {
99                  $rutaNueva = guardarImagenSubida($_FILES[$campo] ?? null, $directorioImagene
    s, "inicio_", $errorImagen);
100                 if ($rutaNueva !== null) {
101                     $imagenesNuevas[] = $rutaNueva;
102                 }
103                 // conservar la imagen actual si no se seleccionó un archivo nuevo
104                 $valoresImagen[$campo] = $rutaNueva ?? (string) ($filaActual[$campo] ?? "");
105             }
106         }
107
108         if ($errorImagen !== null) {
109             // No se guarda nada: se descartan los archivos que sí alcanzaron a subirse en e
    ste envío
110             descartarImagenesSubidas($imagenesNuevas, $directorioImagenes);
111             $mysqli->close();
112             header("Location: index-formulario.php?estado=" . urlencode($errorImagen), true,
     303);
113             exit;
114         }
115
116         $valores = [];
117         foreach ($columnasInicio as $columna) {
118             if (in_array($columna, $camposImagen, true)) {
119                 $valores[] = $valoresImagen[$columna];
120             } elseif ($columna === "paleta_banner") {
121                 // Con un banner nuevo se guarda la paleta calculada de esa imagen; si no, s
    e conserva la actual
122                 if (in_array($valoresImagen["banner_inicio"], $imagenesNuevas, true)) {
123                     $paleta = normalizarPaleta($_POST["paleta_banner"] ?? "");
124                     $valores[] = $paleta ? json_encode($paleta) : "";
125                 } else {
126                     $valores[] = (string) ($filaActual["paleta_banner"] ?? "");
127                 }
128             } elseif ($columna === "url_video_inicio") {
129                 $valores[] = normalizarUrlYoutubeEmbed(trim((string) ($_POST[$columna] ?? ""
    )));
130             } else {
131                 $valores[] = trim((string) ($_POST[$columna] ?? ""));
132             }
133         }
134
135         if ($accion === "crear") {
136             $columnasSql = implode(", ", array_map(fn($c) => "`$c`", $columnasInicio));
137             $marcadores = implode(", ", array_fill(0, count($columnasInicio), "?"));
138             $stmt = $mysqli->prepare("INSERT INTO `inicio` ($columnasSql) VALUES ($marcadore
    s)");
139             $tipos = str_repeat("s", count($valores));
140             $stmt->bind_param($tipos, ...$valores);
141             $estado = $stmt->execute() ? "creado" : "error";
142             $stmt->close();
143         } else {
144             $setClause = implode(", ", array_map(fn($c) => "`$c` = ?", $columnasInicio));
145             $stmt = $mysqli->prepare("UPDATE `inicio` SET $setClause WHERE id_inicio = ?");
146             $tipos = str_repeat("s", count($valores)) . "i";
147             $valores[] = $id;
148             $stmt->bind_param($tipos, ...$valores);
149             $estado = $stmt->execute() ? "actualizado" : "error";
150             $stmt->close();
151         }
152
153         if ($estado === "error") {
154             descartarImagenesSubidas($imagenesNuevas, $directorioImagenes);
155         } elseif ($accion === "editar") {
156             // La imagen antigua que fue reemplazada se borra del almacenamiento; solo queda
     guardada la nueva
157             eliminarImagenesReemplazadas($mysqli, "inicio", $camposImagen, array_map(fn($c)
```

```
    => $filaActual[$c], $camposImagen), $directorioImagenes, $imagenesProtegidas);
158         }
159     }
160
161     $mysqli->close();
162     header("Location: index-formulario.php?estado=" . urlencode($estado), true, 303);
163     exit;
164 }
165
166 $mensajesPorEstado = [
167     "creado" => ["Contenido creado correctamente.", "success"],
168     "actualizado" => ["Contenido actualizado correctamente.", "success"],
169     "eliminado" => ["Contenido eliminado correctamente.", "success"],
170     "error_imagen" => ["Imagen no válida: usa archivos JPG, PNG, GIF o WEBP de máximo 5 MB.
    No se guardaron cambios.", "danger"],
171     "error" => ["No fue posible completar la operación.", "danger"],
172 ];
173 $estadoActual = $_GET["estado"] ?? "";
174 [$mensaje, $tipoMensaje] = $mensajesPorEstado[$estadoActual] ?? ["", "success"];
175
176 $filasInicio = [];
177 $resultado = $mysqli->query("SELECT * FROM `inicio` ORDER BY id_inicio ASC");
178 if ($resultado) {
179     $filasInicio = $resultado->fetch_all(MYSQLI_ASSOC);
180 }
181
182 $acordeones = [1, 2, 3, 4, 5];
183 $colapsables = [1, 2, 3];
```

A. productos/productos-formulario.php (lógica del servidor, líneas 1–156)

```
  1 <?php
  2 declare(strict_types=1);
  3
  4 require_once __DIR__ . "/../inicio/sesion.php";
  5 require_once __DIR__ . "/../inicio/tema.php";
  6 require_once __DIR__ . "/../inicio/imagenes-editor.php";
  7 iniciarSesionSegura();
  8 enviarCabecerasSinCache();
  9
 10 // Solo usuarios autenticados (tabla `usuario`) pueden ver o modificar este editor
 11 if (!usuarioAutenticado()) {
 12     header("Location: productos.php");
 13     exit;
 14 }
 15
 16 $tokenCsrfLogout = generarTokenCsrf();
 17
 18 $mysqli = new mysqli("localhost", "root", "", "tecnico-2026-pagina");
 19 if ($mysqli->connect_error) {
 20     die("Error de conexión: " . $mysqli->connect_error);
 21 }
 22 // Banner y paleta de colores compartidos por todas las páginas
 23 $temaSitio = obtenerTemaSitio($mysqli);
 24
 25 // Columnas de la tabla `productos` que alimentan las variables de productos.php
 26 $columnasProductos = [
 27     "img1_carru_productos", "img2_carru_productos", "img3_carru_productos",
 28     "card_title_productos", "card_texto_productos", "btn_primary_productos",
 29 ];
 30 $camposImagen = ["img1_carru_productos", "img2_carru_productos", "img3_carru_productos"];
 31 $directorioImagenes = __DIR__ . "/img-productos";
 32
 33 // Imágenes que el sitio usa de forma fija: nunca se borran al reemplazar
 34 $imagenesProtegidas = ["banner.png", "footer.png"];
 35
 36 function obtenerProducto(mysqli $mysqli, int $id): ?array
 37 {
 38     $stmt = $mysqli->prepare("SELECT * FROM `productos` WHERE id_producto = ?");
```

```
39      $stmt->bind_param("i", $id);
40      $stmt->execute();
41      $fila = $stmt->get_result()->fetch_assoc();
42      $stmt->close();
43      return $fila ?: null;
44  }
45
46  // Tras procesar el POST se redirige (patrón PRG) a productos-formulario.php sin caché ni re
    envío del formulario
47  // Rechaza envíos del editor sin token CSRF válido (evita modificaciones desde otros sitios)
48  if ($_SERVER["REQUEST_METHOD"] === "POST" && !csrfValido($_POST["csrf_token"] ?? null)) {
49      header("Location: productos-formulario.php?estado=error", true, 303);
50      exit;
51  }
52
53  if ($_SERVER["REQUEST_METHOD"] === "POST") {
54      $accion = $_POST["accion"] ?? "";
55      $estado = "error";
56
57      if ($accion === "eliminar") {
58          $id = (int) ($_POST["id_producto"] ?? 0);
59          $productoActual = $id > 0 ? obtenerProducto($mysqli, $id) : null;
60          if ($productoActual) {
61              $stmt = $mysqli->prepare("DELETE FROM `productos` WHERE id_producto = ?");
62              $stmt->bind_param("i", $id);
63              $estado = $stmt->execute() ? "eliminado" : "error";
64              $stmt->close();
65              if ($estado === "eliminado") {
66                  eliminarImagenesReemplazadas($mysqli, "productos", $camposImagen, array_map(
    fn($c) => $productoActual[$c], $camposImagen), $directorioImagenes, $imagenesProtegidas);
67              }
68          }
69      } elseif ($accion === "crear" || $accion === "editar") {
70          $id = (int) ($_POST["id_producto"] ?? 0);
71          // Las imágenes actuales se leen de la BD (no de campos ocultos que el navegador pod
    ría alterar)
72          $productoActual = $accion === "editar" ? obtenerProducto($mysqli, $id) : [];
73          $valoresImagen = [];
74          $imagenesNuevas = [];
75          $errorImagen = null;
76
77          if ($productoActual === null) {
78              $errorImagen = "error";
79          } else {
80              foreach ($camposImagen as $campo) {
81                  $rutaNueva = guardarImagenSubida($_FILES[$campo] ?? null, $directorioImagene
    s, "producto_", $errorImagen);
82                  if ($rutaNueva !== null) {
83                      $imagenesNuevas[] = $rutaNueva;
84                  }
85                  // conservar la imagen actual si no se seleccionó un archivo nuevo
86                  $valoresImagen[$campo] = $rutaNueva ?? (string) ($productoActual[$campo] ??
    "");
87                  if ($errorImagen === null && $valoresImagen[$campo] === "") {
88                      $errorImagen = "imagen_requerida"; // cada tarjeta necesita sus 3 imágen
    es de carrusel
89                  }
90              }
91          }
92
93          if ($errorImagen !== null) {
94              // No se guarda nada: se descartan los archivos que sí alcanzaron a subirse en e
    ste envío
95              descartarImagenesSubidas($imagenesNuevas, $directorioImagenes);
96              $mysqli->close();
97              header("Location: productos-formulario.php?estado=" . urlencode($errorImagen), t
    rue, 303);
98              exit;
99          }
100
```

```
101         $valores = [];
102         foreach ($columnasProductos as $columna) {
103             $valores[] = in_array($columna, $camposImagen, true)
104                 ? $valoresImagen[$columna]
105                 : trim((string) ($_POST[$columna] ?? ""));
106         }
107 
108         if ($accion === "crear") {
109             $columnasSql = implode(", ", array_map(fn($c) => "`$c`", $columnasProductos));
110             $marcadores = implode(", ", array_fill(0, count($columnasProductos), "?"));
111             $stmt = $mysqli->prepare("INSERT INTO `productos` ($columnasSql) VALUES ($marcad
    ores)");
112             $tipos = str_repeat("s", count($valores));
113             $stmt->bind_param($tipos, ...$valores);
114             $estado = $stmt->execute() ? "creado" : "error";
115             $stmt->close();
116         } else {
117             $setClause = implode(", ", array_map(fn($c) => "`$c` = ?", $columnasProductos));
118             $stmt = $mysqli->prepare("UPDATE `productos` SET $setClause WHERE id_producto =
    ?");
119             $tipos = str_repeat("s", count($valores)) . "i";
120             $valores[] = $id;
121             $stmt->bind_param($tipos, ...$valores);
122             $estado = $stmt->execute() ? "actualizado" : "error";
123             $stmt->close();
124         }
125 
126         if ($estado === "error") {
127             descartarImagenesSubidas($imagenesNuevas, $directorioImagenes);
128         } elseif ($accion === "editar") {
129             // La imagen antigua que fue reemplazada se borra del almacenamiento; solo queda
     guardada la nueva
130             eliminarImagenesReemplazadas($mysqli, "productos", $camposImagen, array_map(fn($
    c) => $productoActual[$c], $camposImagen), $directorioImagenes, $imagenesProtegidas);
131         }
132     }
133 
134     $mysqli->close();
135     header("Location: productos-formulario.php?estado=" . urlencode($estado), true, 303);
136     exit;
137 }
138 
139 $mensajesPorEstado = [
140     "creado" => ["Producto creado correctamente.", "success"],
141     "actualizado" => ["Producto actualizado correctamente.", "success"],
142     "eliminado" => ["Producto eliminado correctamente.", "success"],
143     "error_imagen" => ["Imagen no válida: usa archivos JPG, PNG, GIF o WEBP de máximo 5 MB.
    No se guardaron cambios.", "danger"],
144     "imagen_requerida" => ["Cada producto necesita las 3 imágenes del carrusel. No se guarda
    ron cambios.", "danger"],
145     "error" => ["No fue posible completar la operación.", "danger"],
146 ];
147 $estadoActual = $_GET["estado"] ?? "";
148 [$mensaje, $tipoMensaje] = $mensajesPorEstado[$estadoActual] ?? ["", "success"];
149 
150 $filasProductos = [];
151 $resultado = $mysqli->query("SELECT * FROM `productos` ORDER BY id_producto ASC");
152 if ($resultado) {
153     $filasProductos = $resultado->fetch_all(MYSQLI_ASSOC);
154 }
155 $mysqli->close();
```

A. contacto/contactos-formulario.php (lógica del servidor, líneas 1–70)

```php
<?php
declare(strict_types=1);

require_once __DIR__ . "/../inicio/sesion.php";
require_once __DIR__ . "/../inicio/tema.php";
iniciarSesionSegura();
enviarCabecerasSinCache();

// Solo usuarios autenticados (tabla `usuario`) pueden ver o modificar este editor
if (!usuarioAutenticado()) {
    header("Location: contactos.php");
    exit;
}

$tokenCsrfLogout = generarTokenCsrf();

$mysqli = new mysqli("localhost", "root", "", "tecnico-2026-pagina");
if ($mysqli->connect_error) {
    die("Error de conexión: " . $mysqli->connect_error);
}
// Banner y paleta de colores compartidos por todas las páginas
$temaSitio = obtenerTemaSitio($mysqli);

// Tras procesar el POST se redirige (patrón PRG) a contactos-formulario.php sin caché ni re
envío del formulario
// Rechaza envíos del editor sin token CSRF válido (evita modificaciones desde otros sitios)
if ($_SERVER["REQUEST_METHOD"] === "POST" && !csrfValido($_POST["csrf_token"] ?? null)) {
    header("Location: contactos-formulario.php?estado=error", true, 303);
    exit;
}

if ($_SERVER["REQUEST_METHOD"] === "POST") {
    $accion = $_POST["accion"] ?? "";
    $estado = "error";
    $urlContacto = trim((string) ($_POST["url_contacto"] ?? ""));

    if ($urlContacto !== "") {
        if ($accion === "crear") {
            $stmt = $mysqli->prepare("INSERT INTO `contacto` (url_contacto) VALUES (?)");
            $stmt->bind_param("s", $urlContacto);
            $estado = $stmt->execute() ? "creado" : "error";
            $stmt->close();
        } elseif ($accion === "editar") {
            $id = (int) ($_POST["id_contacto"] ?? 0);
            $stmt = $mysqli->prepare("UPDATE `contacto` SET url_contacto = ? WHERE id_contac
to = ?");
            $stmt->bind_param("si", $urlContacto, $id);
            $estado = $stmt->execute() ? "actualizado" : "error";
            $stmt->close();
        }
    }

    $mysqli->close();
    header("Location: contactos-formulario.php?estado=" . urlencode($estado), true, 303);
    exit;
}

$mensajesPorEstado = [
    "creado" => ["URL del mapa creada correctamente.", "success"],
    "actualizado" => ["URL del mapa actualizada correctamente.", "success"],
    "error" => ["No fue posible completar la operación.", "danger"],
];
$estadoActual = $_GET["estado"] ?? "";
[$mensaje, $tipoMensaje] = $mensajesPorEstado[$estadoActual] ?? ["", "success"];

$filaContacto = [];
$resultado = $mysqli->query("SELECT * FROM `contacto` ORDER BY id_contacto ASC LIMIT 1");
if ($resultado && $resultado->num_rows > 0) {
```

```
    $filaContacto = $resultado->fetch_assoc();
}
$mysqli->close();
```

A. inicio/index.php (lógica del servidor, líneas 1–69)

```
<?php
declare(strict_types=1);

require_once __DIR__ . "/sesion.php";
require_once __DIR__ . "/tema.php";
iniciarSesionSegura();
enviarCabecerasSinCache();
$tokenCsrfLogin = generarTokenCsrf();

$mysqli = new mysqli("localhost", "root", "", "tecnico-2026-pagina");
if ($mysqli->connect_error) {
    die("Error de conexión: " . $mysqli->connect_error);
}
// Banner y paleta de colores compartidos por todas las páginas
$temaSitio = obtenerTemaSitio($mysqli);

// Convierte enlaces de YouTube (watch, youtu.be, shorts) al formato /embed/ requerido por el iframe
function normalizarUrlYoutubeEmbed(string $url): string
{
    $url = trim($url);
    if ($url === "") {
        return $url;
    }
    if (preg_match('~(?:youtu\.be/|youtube\.com/(?:embed/|watch\?v=|shorts/))([A-Za-z0-9_-]{6,})~i', $url, $coincidencia)) {
        return "https://www.youtube.com/embed/" . $coincidencia[1];
    }
    return $url;
}

// Valores de respaldo si la tabla `inicio` aún no tiene registros
$datosInicio = [
    "banner_inicio" => "./img-inicio/banner.png",
    "carru-1" => "./img-inicio/1.jpeg",
    "carru-2" => "./img-inicio/2.jpeg",
    "carru-3" => "./img-inicio/3.jpeg",
    "url_video_inicio" => "https://www.youtube.com/embed/crdtrzZj3fo?si=__NqB1aheTtDAYfc",
    "acor1_titulo_inicio" => "Margarita (Margherita)",
    "acor1_texto_inicio" => "La reina de las pizzas. Salsa de tomate, mozzarella fresca, albahaca y aceite de oliva.",
    "acor2_titulo_inicio" => "Cuatro Quesos (Quattro Formaggi)",
    "acor2_texto_inicio" => "Una mezcla de quesos fundidos, usualmente mozzarella, gorgonzola (azul), fontina y parmesano.",
    "acor3_titulo_inicio" => "Napolitana",
    "acor3_texto_inicio" => "Salsa de tomate, anchoas, ajo, orégano y aceite de oliva (tradicionalmente no lleva queso).",
    "acor4_titulo_inicio" => "Mexicana",
    "acor4_texto_inicio" => "Incluye carne molida o chorizo, frijoles negros, jalapeños, cebolla y un toque de aguacate o cilantro.",
    "acor5_titulo_inicio" => "Barbacoa (BBQ)",
    "acor5_texto_inicio" => "Sustituye la salsa de tomate por salsa barbacoa, acompañada de pollo, carne picada, cebolla y bacon.",
    "colapsar1_titulo_inicio" => "Vegetariana",
    "colapsar1_texto_inicio" => "Cubierta de vegetales frescos o salteados, como pimientos, cebolla, champiñones, aceitunas y tomates cherry.",
    "colapsar2_titulo_inicio" => "Funghi (Champiñones)",
    "colapsar2_texto_inicio" => "Base de mozzarella con abundantes hongos salteados, a veces con un toque de aceite de trufa.",
    "colapsar3_titulo_inicio" => "Cuatro Estaciones (Quattro Stagioni)",
    "colapsar3_texto_inicio" => "Dividida en cuatro secciones, cada una representando una estación con ingredientes distintos (por ejemplo: alcachofas, champiñones, jamón y albahaca)."
,
```

```
    "numero_whatsapp" => "573132345685",
];

$resultadoInicio = $mysqli->query("SELECT * FROM `inicio` ORDER BY id_inicio ASC LIMIT 1");
if ($resultadoInicio && $resultadoInicio->num_rows > 0) {
    $filaInicio = $resultadoInicio->fetch_assoc();
    foreach ($datosInicio as $campo => $valorPorDefecto) {
        $valor = trim((string) ($filaInicio[$campo] ?? ""));
        $datosInicio[$campo] = $valor !== "" ? $valor : $valorPorDefecto;
    }
}

$mysqli->close();

$datosInicio["url_video_inicio"] = normalizarUrlYoutubeEmbed($datosInicio["url_video_inicio"]);
$whatsappInicio = preg_replace('/\D/', '', $datosInicio["numero_whatsapp"]);
?>
```

A. productos/productos.php (lógica del servidor, líneas 1–26)

```
<?php
declare(strict_types=1);

require_once __DIR__ . "/../inicio/sesion.php";
require_once __DIR__ . "/../inicio/tema.php";
iniciarSesionSegura();
enviarCabecerasSinCache();
$tokenCsrfLogin = generarTokenCsrf();

$mysqli = new mysqli("localhost", "root", "", "tecnico-2026-pagina");
if ($mysqli->connect_error) {
    die("Error de conexión: " . $mysqli->connect_error);
}
// Banner y paleta de colores compartidos por todas las páginas
$temaSitio = obtenerTemaSitio($mysqli);

// Todo el contenido de la tabla `productos` se vuelca a variables PHP antes de imprimir HTML
$productos = [];
$resultadoProductos = $mysqli->query("SELECT * FROM `productos` ORDER BY id_producto ASC");
if ($resultadoProductos) {
    $productos = $resultadoProductos->fetch_all(MYSQLI_ASSOC);
}
$mysqli->close();

$filasProductos = array_chunk($productos, 4);
?>
```

A. contacto/contactos.php (lógica del servidor, líneas 1–28)

```
<?php
declare(strict_types=1);

require_once __DIR__ . "/../inicio/sesion.php";
require_once __DIR__ . "/../inicio/tema.php";
iniciarSesionSegura();
enviarCabecerasSinCache();
$tokenCsrfLogin = generarTokenCsrf();

$mysqli = new mysqli("localhost", "root", "", "tecnico-2026-pagina");
if ($mysqli->connect_error) {
    die("Error de conexión: " . $mysqli->connect_error);
}
// Banner y paleta de colores compartidos por todas las páginas
$temaSitio = obtenerTemaSitio($mysqli);

```

```php
// El contenido de la tabla `contacto` se vuelca a variables PHP antes de imprimir HTML
$urlContacto = "https://www.google.com/maps/embed?pb=!1m18!1m12!1m3!1d18953.883843598873!2d-75.2785308969908!3d2.9410217172291766!2m3!1f0!2f0!3f0!3m2!1i1024!2i768!4f13.1!3m3!1m2!1s0x8e3b7464ac59aa5b%3A0x7e513d68543b6eec!2sDomino's%20Pizza%20Las%20Brisas!5e0!3m2!1ses-419!2sco!4v1784748693148!5m2!1ses-419!2sco";
$resultadoContacto = $mysqli->query("SELECT * FROM `contacto` ORDER BY id_contacto ASC LIMIT 1");
if ($resultadoContacto && $resultadoContacto->num_rows > 0) {
    $filaContacto = $resultadoContacto->fetch_assoc();
    $valor = trim((string) ($filaContacto["url_contacto"] ?? ""));
    if ($valor !== "") {
        $urlContacto = $valor;
    }
}
$mysqli->close();
?>
```

A. inicio/tema.js

```javascript
// Tema compartido por todas las páginas: aplica el banner y su paleta de colores sin recargar
(function () {
  var CLAVE_AVISO = "pizzaJulianTemaActualizado";

  function estiloTema() {
    return document.getElementById("tema-sitio");
  }

  function aplicarTema(tema) {
    var raiz = document.documentElement;
    Object.keys(tema.paleta).forEach(function (clave) {
      raiz.style.setProperty("--pizza-" + clave, tema.paleta[clave]);
    });
    raiz.style.setProperty("--banner-url", 'url("' + tema.banner + '")');
    document.querySelectorAll(".banner img").forEach(function (img) {
      img.src = tema.banner;
    });
    if (tema.version && estiloTema()) {
      estiloTema().dataset.version = tema.version;
    }
  }

  // Quita la vista previa y vuelve a los valores que imprimió el servidor
  function restaurarTema(bannerOriginal) {
    var raiz = document.documentElement;
    Array.prototype.slice.call(raiz.style).forEach(function (propiedad) {
      if (propiedad.indexOf("--pizza-") === 0 || propiedad === "--banner-url") {
        raiz.style.removeProperty(propiedad);
      }
    });
    document.querySelectorAll(".banner img").forEach(function (img) {
      img.src = bannerOriginal;
    });
  }

  // Consulta el tema guardado y lo aplica si cambió (otro editor actualizó el banner)
  function sincronizarTema() {
    fetch("../inicio/tema-json.php", { cache: "no-store", credentials: "same-origin" })
      .then(function (respuesta) { return respuesta.json(); })
      .then(function (tema) {
        var versionActual = estiloTema() ? estiloTema().dataset.version : "";
        if (tema.ok && tema.version !== versionActual) {
          aplicarTema(tema);
        }
      })
      .catch(function () {});
  }

  function avisarTemaActualizado() {
```

```
50      try {
51        localStorage.setItem(CLAVE_AVISO, String(Date.now()));
52      } catch (e) {}
53    }
54
55    // ---- Paleta a partir de la imagen del banner ----
56    function hslAHex(h, s, l) {
57      h = ((h % 360) + 360) % 360;
58      var c = (1 - Math.abs(2 * l - 1)) * s;
59      var x = c * (1 - Math.abs(((h / 60) % 2) - 1));
60      var m = l - c / 2;
61      var rgb = h < 60 ? [c, x, 0] : h < 120 ? [x, c, 0] : h < 180 ? [0, c, x] : h < 240 ? [0,
     x, c] : h < 300 ? [x, 0, c] : [c, 0, x];
62      return "#" + rgb.map(function (v) {
63        return ("0" + Math.round((v + m) * 255).toString(16)).slice(-2);
64      }).join("");
65    }
66
67    function luminancia(hex) {
68      var canales = [1, 3, 5].map(function (i) {
69        var v = parseInt(hex.substr(i, 2), 16) / 255;
70        return v <= 0.03928 ? v / 12.92 : Math.pow((v + 0.055) / 1.055, 2.4);
71      });
72      return 0.2126 * canales[0] + 0.7152 * canales[1] + 0.0722 * canales[2];
73    }
74
75    function rgbAHsl(r, g, b) {
76      r /= 255; g /= 255; b /= 255;
77      var max = Math.max(r, g, b), min = Math.min(r, g, b);
78      var h = 0, s = 0, l = (max + min) / 2;
79      if (max !== min) {
80        var d = max - min;
81        s = l > 0.5 ? d / (2 - max - min) : d / (max + min);
82        h = max === r ? (g - b) / d + (g < b ? 6 : 0) : max === g ? (b - r) / d + 2 : (r - g)
    / d + 4;
83        h *= 60;
84      }
85      return [h, s, l];
86    }
87
88    function distanciaTono(a, b) {
89      var d = Math.abs(a - b) % 360;
90      return d > 180 ? 360 - d : d;
91    }
92
93    // Ajusta la luminosidad hasta cumplir el contraste que necesita cada rol del diseño
94    function colorConLuminancia(tono, saturacion, luz, paso, cumple) {
95      var hex = hslAHex(tono, saturacion, luz);
96      while (!cumple(luminancia(hex)) && luz > 0.05 && luz < 0.9) {
97        luz += paso;
98        hex = hslAHex(tono, saturacion, luz);
99      }
100     return hex;
101   }
102
103   // Devuelve la paleta {negro, naranja, ...} con los tonos del banner, o null si la imagen
    no tiene colores definidos
104   function extraerPaletaBanner(imagen) {
105     var ancho = 160;
106     var alto = Math.max(1, Math.round(imagen.naturalHeight * ancho / imagen.naturalWidth));
107     var lienzo = document.createElement("canvas");
108     lienzo.width = ancho;
109     lienzo.height = alto;
110     var contexto = lienzo.getContext("2d", { willReadFrequently: true });
111     contexto.drawImage(imagen, 0, 0, ancho, alto);
112     var pixeles = contexto.getImageData(0, 0, ancho, alto).data;
113
114     // histograma de tonos (36 grupos de 10°) de los píxeles con color vivo
115     var pesos = new Array(36).fill(0);
116     for (var i = 0; i < pixeles.length; i += 4) {
```

```
      var hsl = rgbAHsl(pixeles[i], pixeles[i + 1], pixeles[i + 2]);
      if (hsl[1] > 0.45 && hsl[2] > 0.25 && hsl[2] < 0.75) {
        pesos[Math.floor(hsl[0] / 10) % 36] += hsl[1];
      }
    }
    var maximo = Math.max.apply(null, pesos);
    if (maximo < ancho * alto * 0.01) {
      return null; // imagen casi en blanco y negro: se usa la paleta por defecto
    }

    // tono principal: promedio circular del grupo dominante y sus vecinos
    var principal = pesos.indexOf(maximo);
    var sumaX = 0, sumaY = 0;
    [-1, 0, 1].forEach(function (desplazamiento) {
      var grupo = (principal + desplazamiento + 36) % 36;
      var angulo = (grupo * 10 + 5) * Math.PI / 180;
      sumaX += Math.cos(angulo) * pesos[grupo];
      sumaY += Math.sin(angulo) * pesos[grupo];
    });
    var tonoNaranja = (Math.atan2(sumaY, sumaX) * 180 / Math.PI + 360) % 360;

    // entre los tonos importantes, el más oscuro hace de "rojo" y el más claro de "amarillo"
    var luzDeTono = function (tono) { return luminancia(hslAHex(tono, 1, 0.5)); };
    var tonoRojo = tonoNaranja, tonoAmarillo = tonoNaranja;
    pesos.forEach(function (peso, grupo) {
      if (peso < maximo * 0.15) {
        return;
      }
      var tono = grupo * 10 + 5;
      if (luzDeTono(tono) < luzDeTono(tonoRojo)) { tonoRojo = tono; }
      if (luzDeTono(tono) > luzDeTono(tonoAmarillo)) { tonoAmarillo = tono; }
    });
    if (distanciaTono(tonoRojo, tonoNaranja) < 15) {
      tonoRojo = luzDeTono(tonoNaranja - 25) < luzDeTono(tonoNaranja + 25) ? tonoNaranja - 25 : tonoNaranja + 25;
    }
    if (distanciaTono(tonoAmarillo, tonoNaranja) < 10) {
      tonoAmarillo = luzDeTono(tonoNaranja - 15) > luzDeTono(tonoNaranja + 15) ? tonoNaranja - 15 : tonoNaranja + 15;
    }

    // mismas saturaciones y luces que el diseño original: solo cambian los tonos
    var naranja = colorConLuminancia(tonoNaranja, 1, 0.55, 0.02, function (lum) { return lum >= 0.38; });
    return {
      "negro": hslAHex(tonoRojo, 0.25, 0.047),
      "negro-suave": hslAHex(tonoRojo, 0.21, 0.084),
      "naranja": naranja,
      "amarillo": colorConLuminancia(tonoAmarillo, 1, 0.55, 0.02, function (lum) { return lum >= Math.max(0.55, luminancia(naranja) + 0.1); }),
      "rojo": colorConLuminancia(tonoRojo, 0.91, 0.445, -0.02, function (lum) { return lum <= 0.16; }),
      "rojo-profundo": colorConLuminancia(tonoRojo, 0.88, 0.3, -0.02, function (lum) { return lum <= 0.07; }),
      "rojo-vivo": colorConLuminancia(tonoRojo, 1, 0.59, -0.02, function (lum) { return lum <= 0.3; }),
      "blanco": hslAHex(tonoNaranja, 0.2, 0.96),
      "gris": hslAHex(tonoNaranja, 0.17, 0.89),
    };
  }

  // Otra pestaña guardó un banner nuevo: aplicar el tema al instante
  window.addEventListener("storage", function (evento) {
    if (evento.key === CLAVE_AVISO) {
      sincronizarTema();
    }
  });
  // Al volver a una pestaña que estaba en segundo plano se revisa si el tema cambió
  document.addEventListener("visibilitychange", function () {
```

```
179      if (document.visibilityState === "visible") {
180        sincronizarTema();
181      }
182    });
183
184    window.temaSitio = {
185      aplicarTema: aplicarTema,
186      restaurarTema: restaurarTema,
187      sincronizarTema: sincronizarTema,
188      avisarTemaActualizado: avisarTemaActualizado,
189      extraerPaletaBanner: extraerPaletaBanner,
190    };
191  })();
```

Elaborado por el ingeniero desarrollador **ALBER DELFIN PEÑA ORTIGOZA**
Programa TÉCNICO EN PROGRAMACIÓN DE SOFTWARE
SENA – INSTITUCIÓN EDUCATIVA TÉCNICO SUPERIOR